CYBER RISK
DEFENDERS CLUB

PHOENIX SECURITY

WEBINAR

CYBER RESILIENCE REAL TALK: A CISO'S TAKE ON APPLICATION SECURITY, THREAT CENTRIC APPROACH WITH RICK DOTEN

Rick Doten

VP, HEALTHPLAN CISO, CENTENE CORPORATION | CYBERSECURITY STRATEGIST

www.phoenix.security.com 23 April

10 AM PST / 12 AM CT / 1 PM ET/ 5 PM GMT

Agenda – Rick D

- Intro
- Vulnerability Landscape
- CVE Drama
- Threat Centric Approach on vulnerability

Vulnerability growth outpaces the ability of defender to react. Automation is the only solution

Only 1-10%

of these is actually relevant *

Only 6%

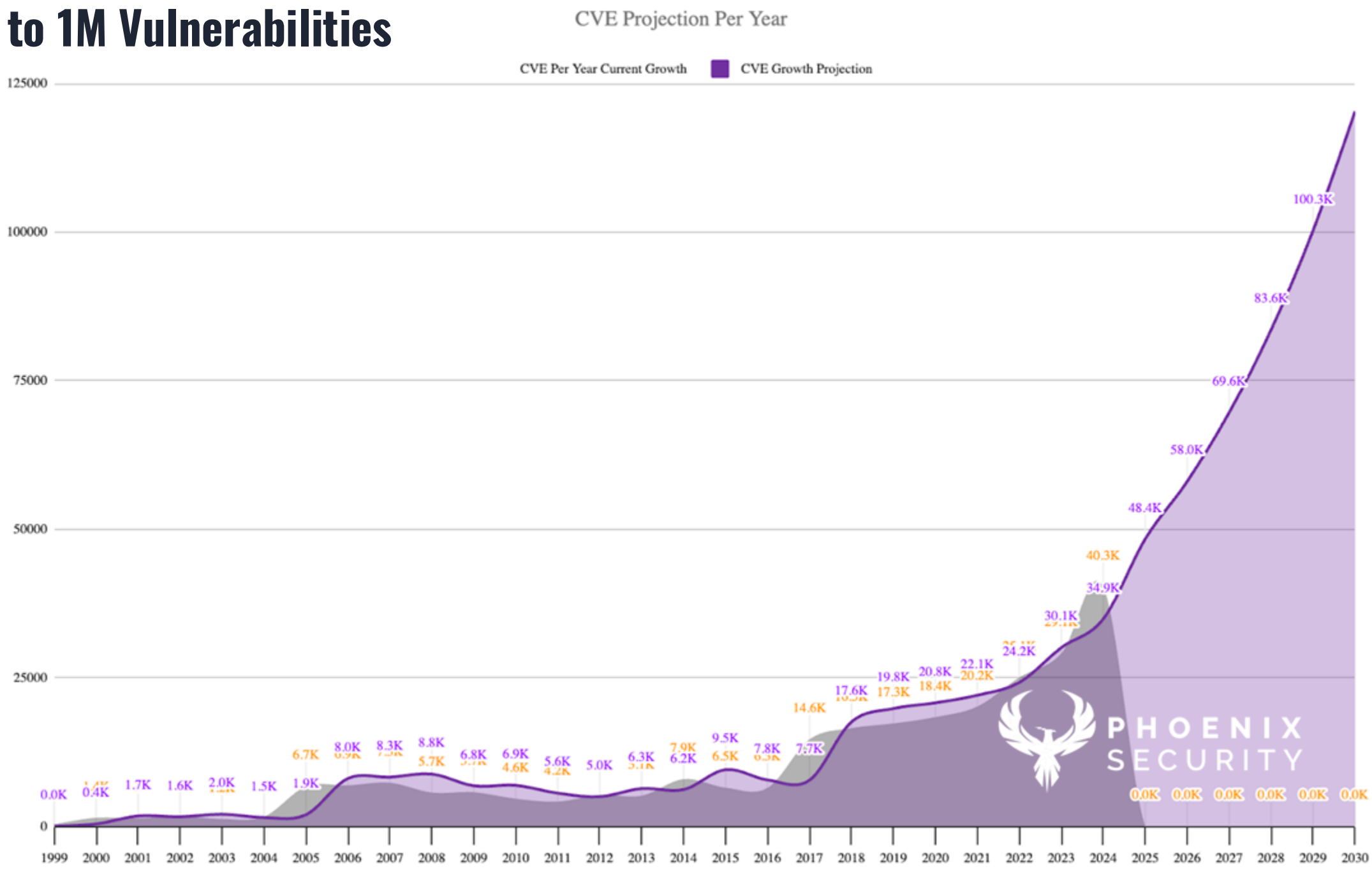
Budget increase for security team down from 17% ***

0%

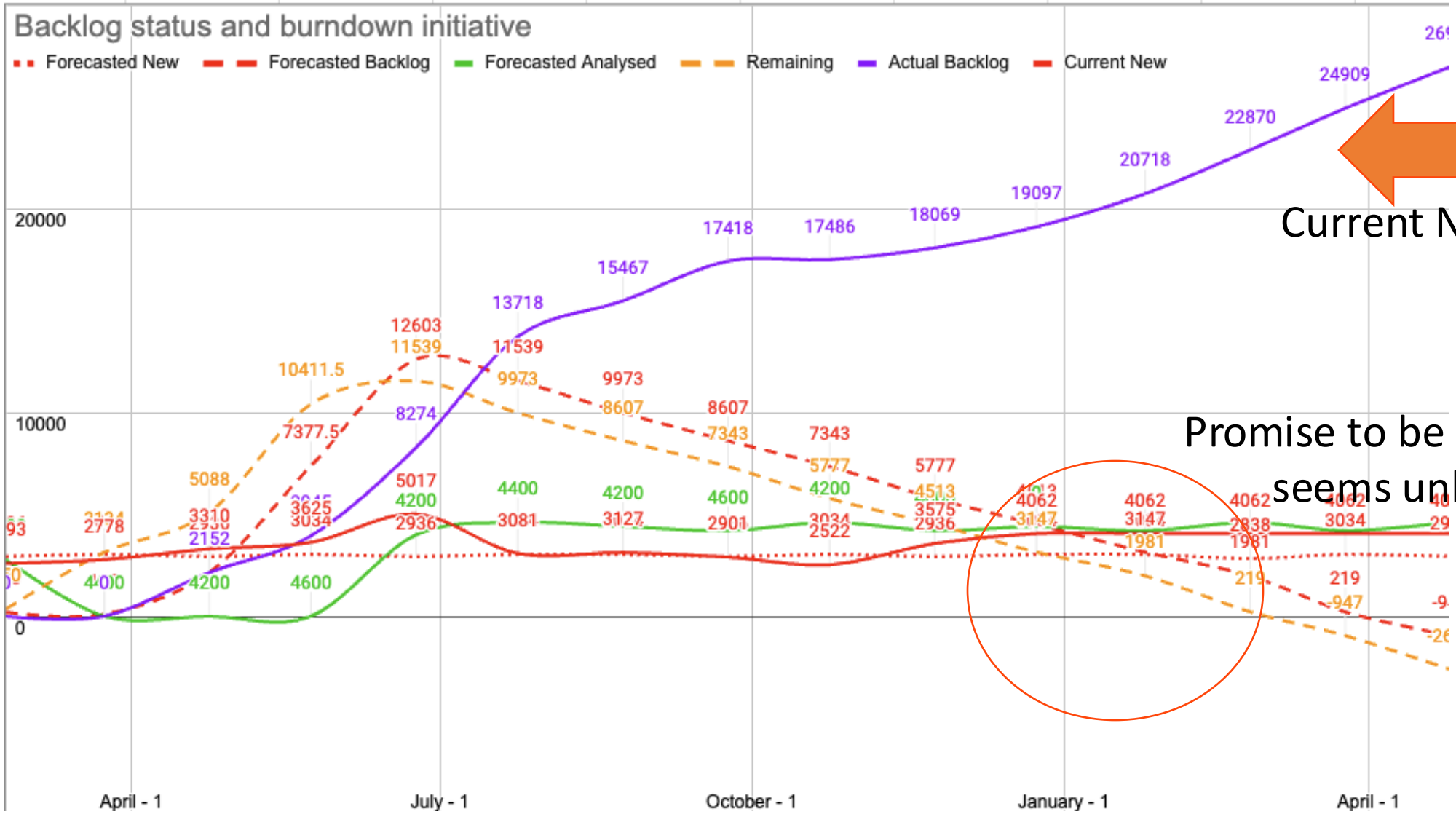
We can go home ☺

*FIST / EPSS ** NVD/CVE STATISTICS *** UK GOVERNMENT

Road to 1M Vulnerabilities



Challenge: we need clean data to act on systemic vulnerabilities
But we have a problem with data quality and enrichment



Current NVD BACKLOG

Promise to be close to 0 seems unlikely

Vulnerability -> Threat Centric

FROM VULNERABILITY MANAGEMENT TO THREAT BASED THREAT REDUCTION

WHY? - BUSINESS VALUE

PREVENTION
Reduced Impact - less likely to be — breached / / ransomwared

PREVENTION
Reduced cost of downtime

PREVENTION
Reduce time to fix

OPTIMIZATION
Increased operational efficiency / Remediation / / Reaction Time

WHAT?

FIX BASED ON THREAT
- Reduce exposure by reducing attack surface
- Reduce exposure of threat actor
- Threat intelligence focused remediation
- Reduce exposure of ransomware techniques

FIX FAST & WITH PRECISION
- Asset ownership
- Sending the right vulnerability vulnerability to the right team team
- Contextual deduplication
- Remove noise & false positive positive
- Contextual prioritization
- Implement the most important fix: fix suggestions

SCALE SECURITY TEAMS
- Assess exposure to weaponization threat actors actors and ransomware
- Identify the trends: what methodology of attack is more applicable

HOW?

EXPOSURE MANAGEMENT
- Augment Vulnerability with Categorization
- Map the vulnerabilities and attack vector to threat actors
- Exploited threat Intelligence Intelligence
- Exploit evidence
- Weaponization evidence
- Use in attacks
- Use in ransomware
- Use in wild

Fix and Reduce Attack surface exposed to threat actors

OWNERSHIP
- Auto ownership / Auto mapping of user to assets
- Repository to container / Cloud auto mapping
- Suggest cloud ownership from code
- Automatic grouping of application and services

Suggest the right fix to the right team

REMEDY/ PREVENT
- Contextual Prioritization
- Contextual deduplication / remove container vulnerability / active container monitoring
- Remove false positives
- High quality signal
- Group vulnerabilities by fixes
- Suggest the most risk impacting vulnerabilities
- Systemic campaign Remediation
- No code exception & workflows

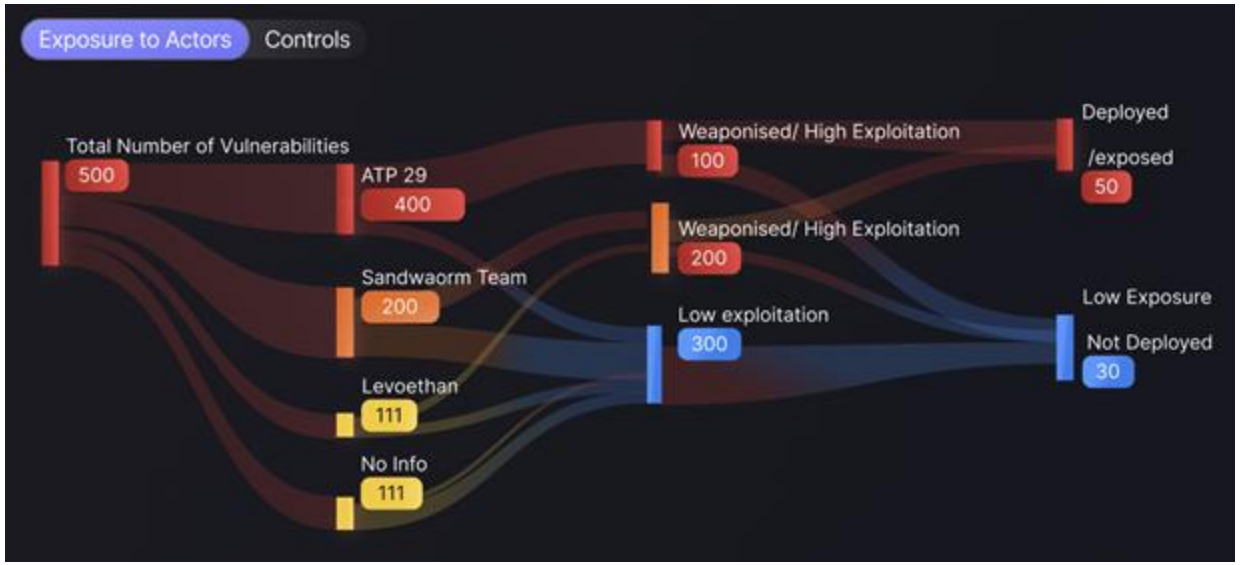
Hight quality signal / own your narrative

INSIGTS & PROACTIVE
- Focus on remediation by category of issues
- Campaign suggestion on what is most important
- Risk based target delivering actions for engineers
- Security Insight for security teams
- Security Champion Programs

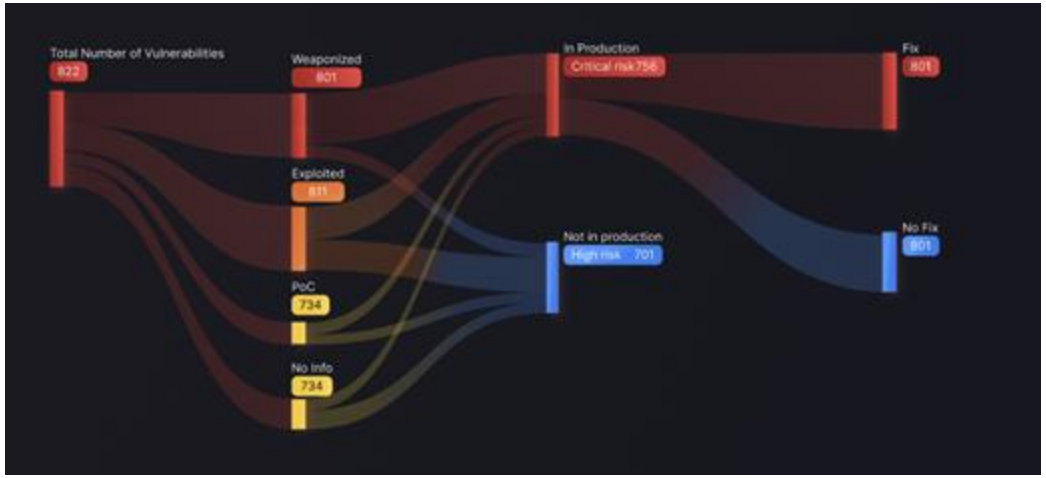
Answering Question – What threat AM I EXPOSED

What are your exposure to Ransomware

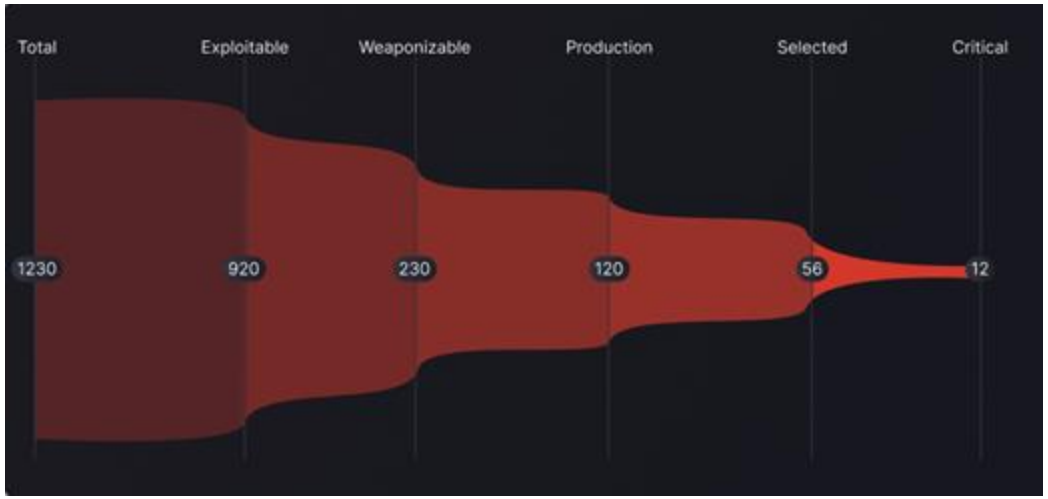
How exposed are you to threat actor X/Y/Z



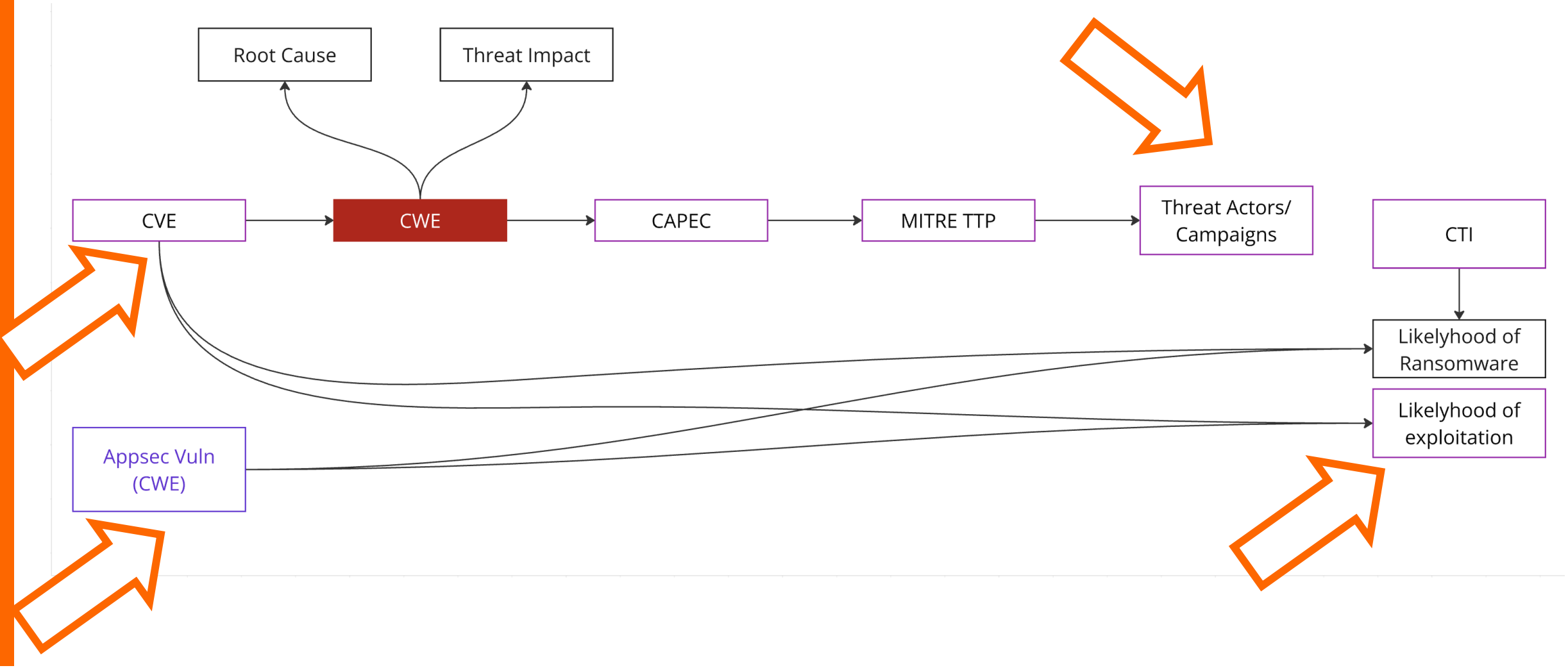
How many exploitable/Weaponizable vulnerability you have



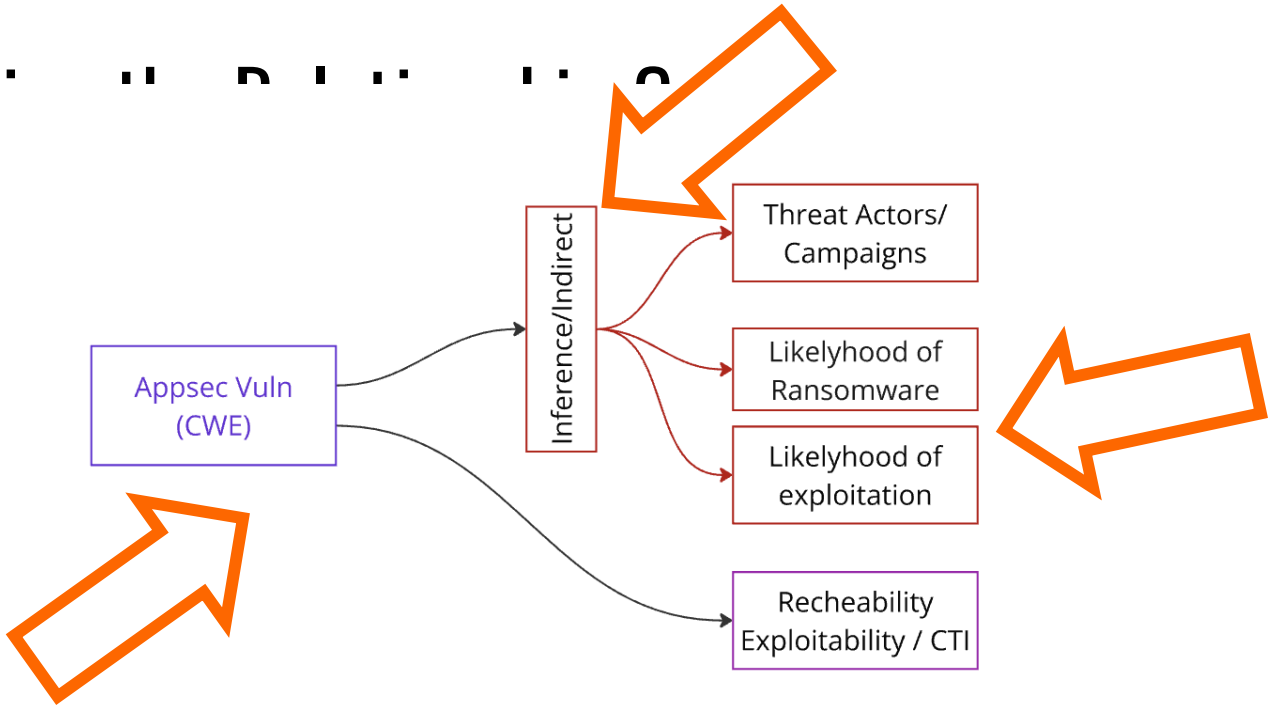
How many Vulnerabilities are actually important



Relationship Gap

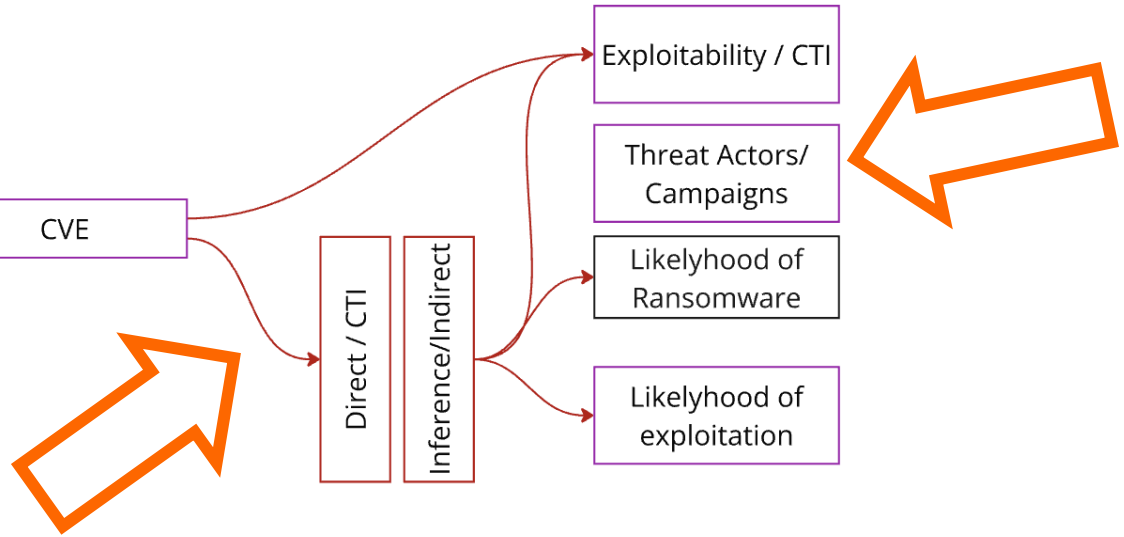


Fill



For CWE ? Appsec Vulnerabilities

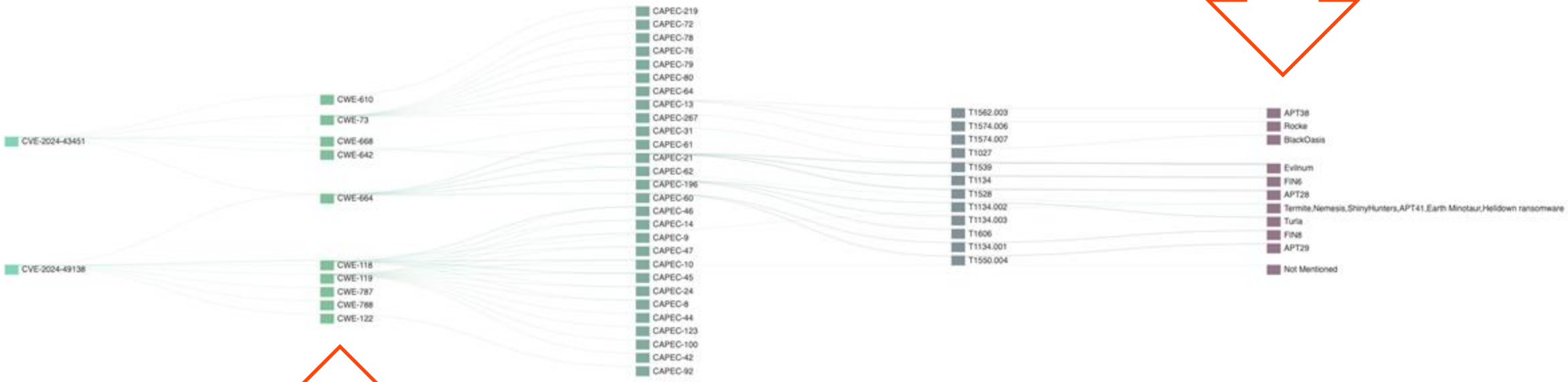
- Knowing the threat actors
- Apply CTI / indirectly
- Knowing possibly of ransomware and exploitation



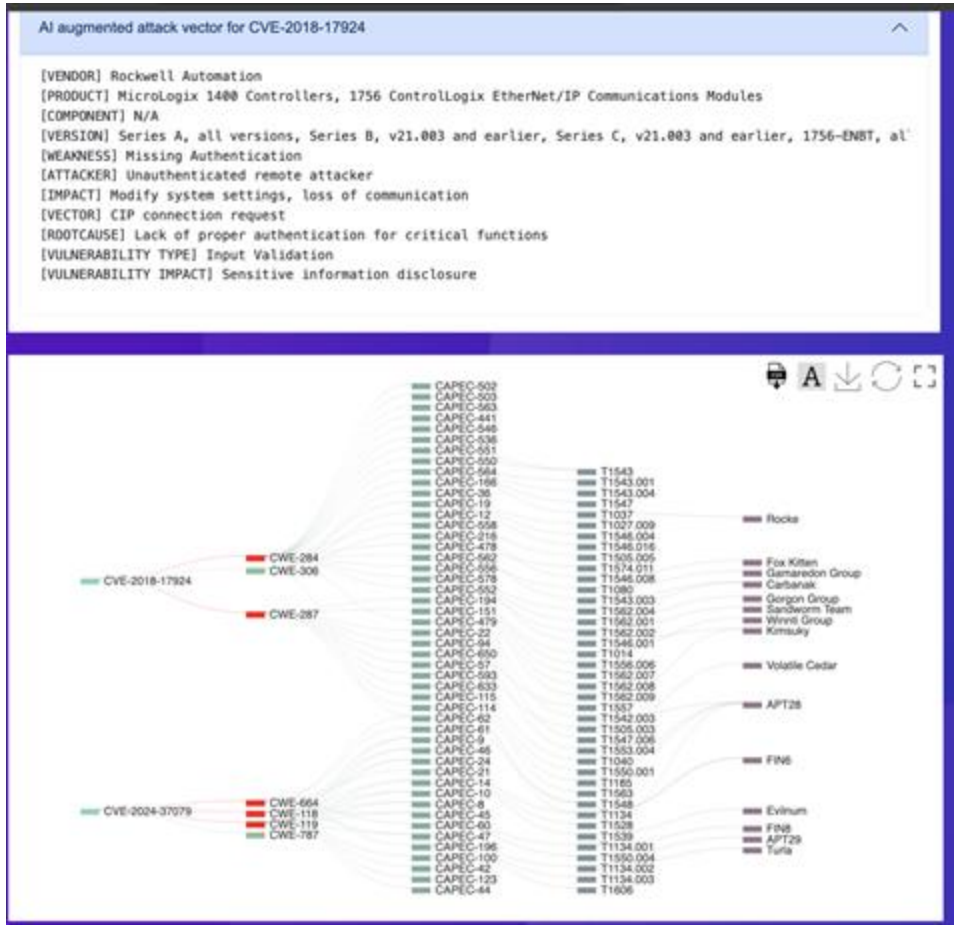
For CVE based

- Knowing and increasing the coverage CVE – Threat Actor / Technique
- Knowing Which technique is more used
- Use this as probabilistic methods

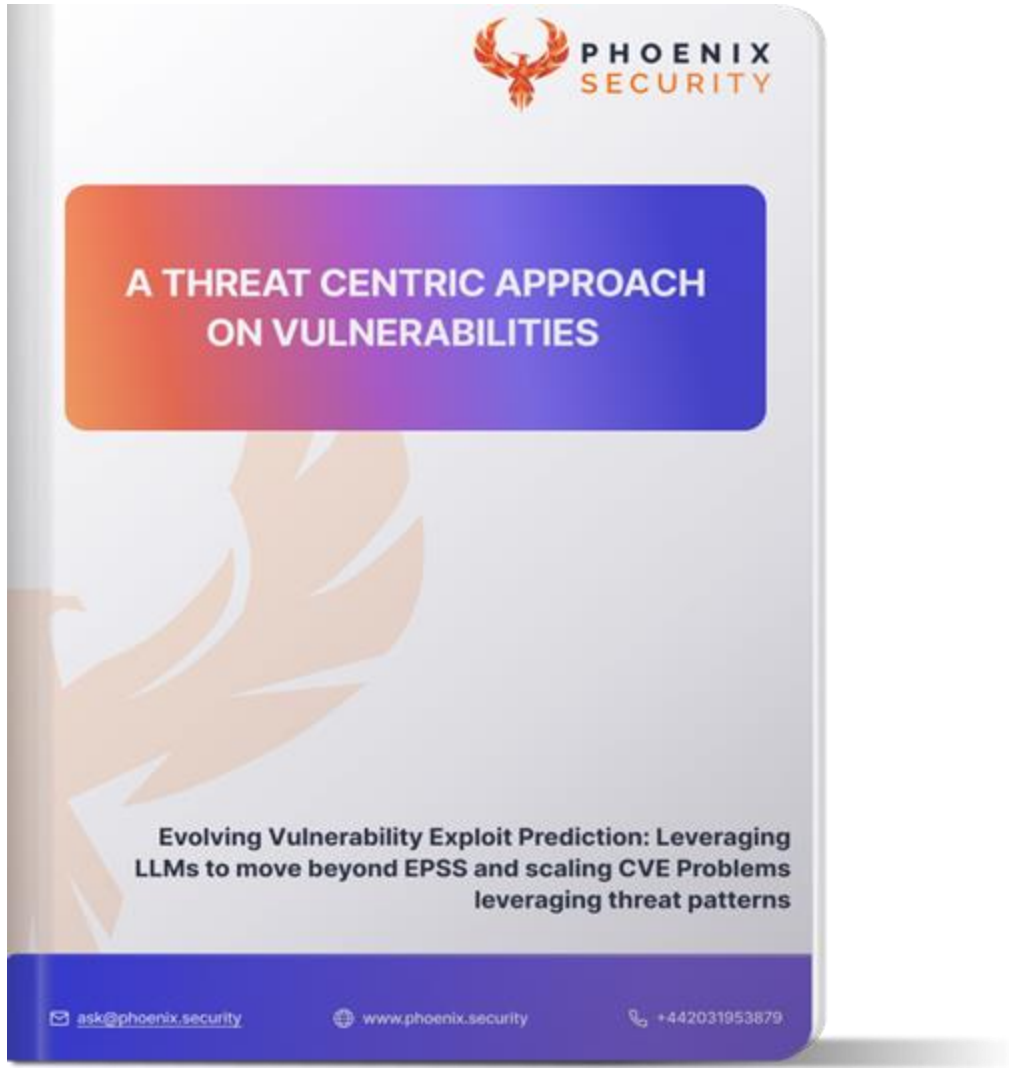
Challenge – Description of vulnerabilities IS NOT root cause analysis



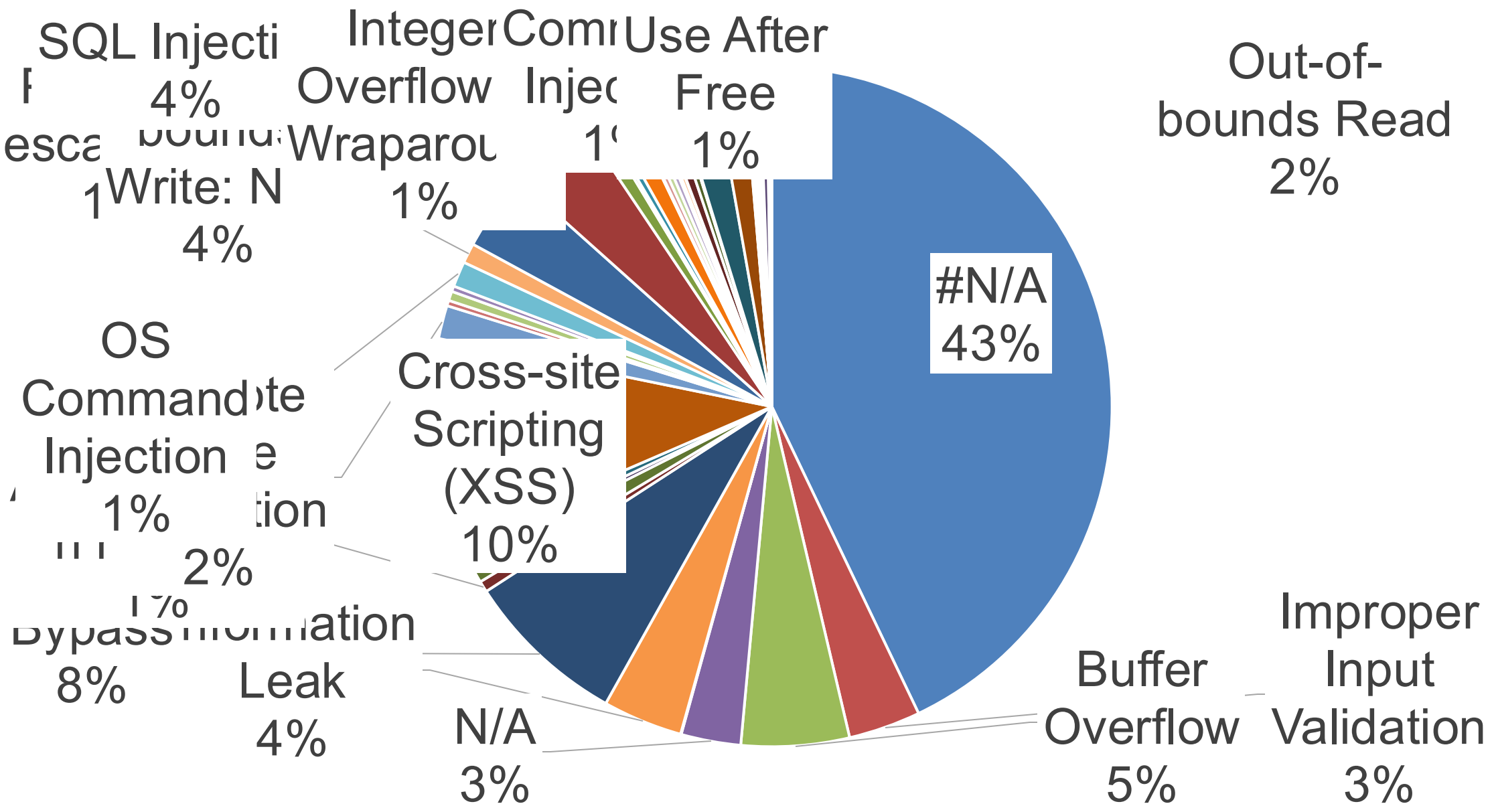
Threat Centric Approach on vulnerabilities



New Whitepaper LLM for a Threat Centric Approach

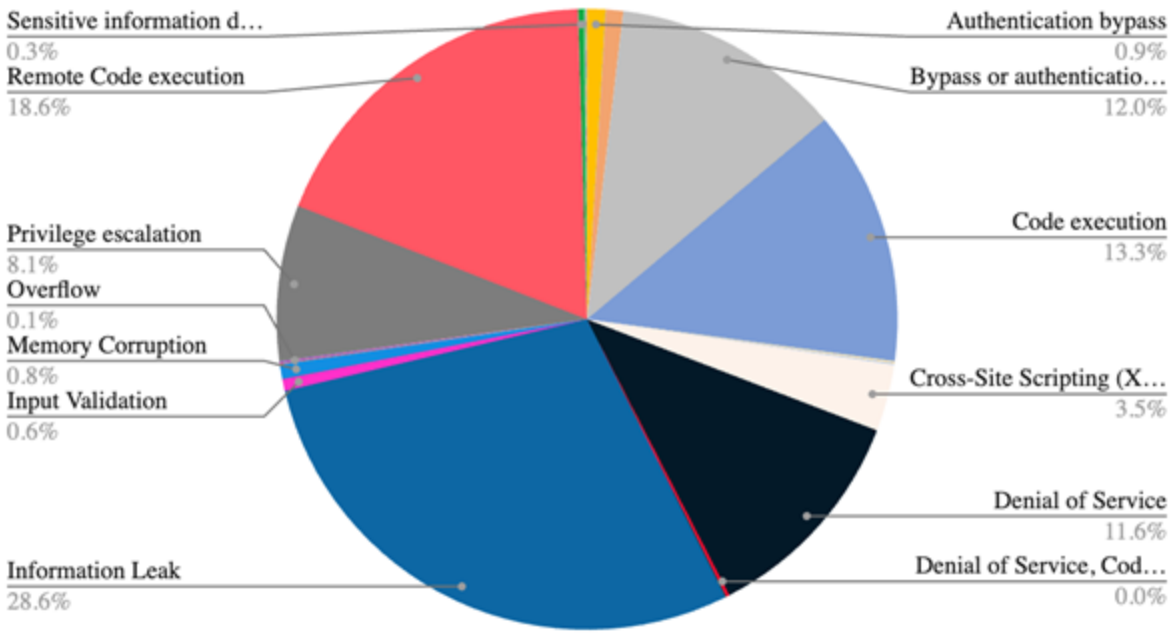


Current CWE Completion – 50% incomplete

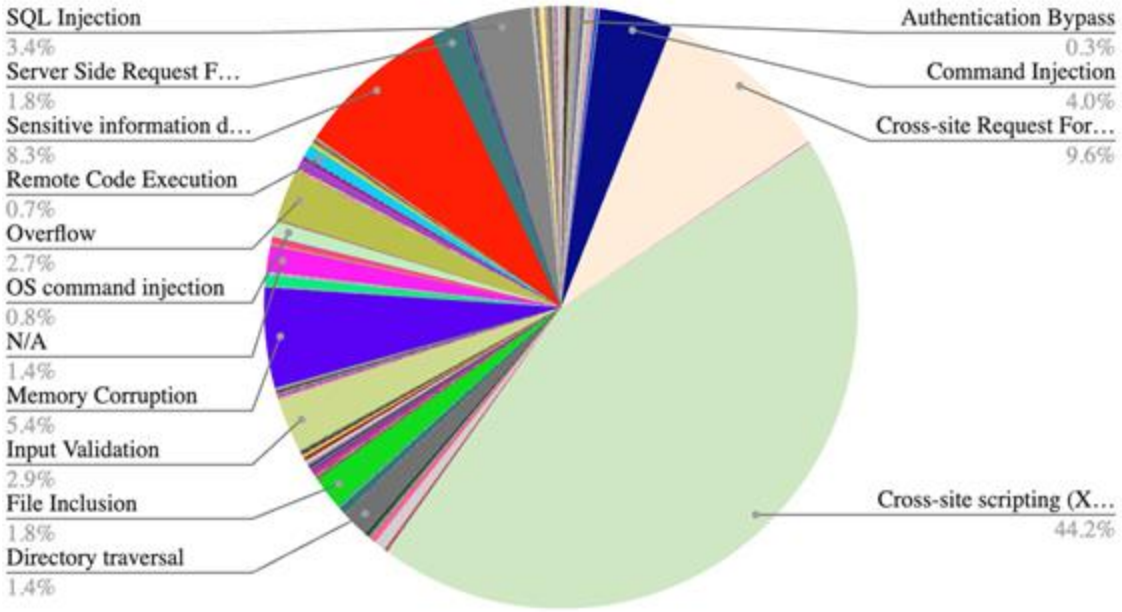


Way Ahead LLM Generation of Simplified Description of vulnerabilities, root cause and technical impact

Threat Root Cause



Threat Impact / Weakness

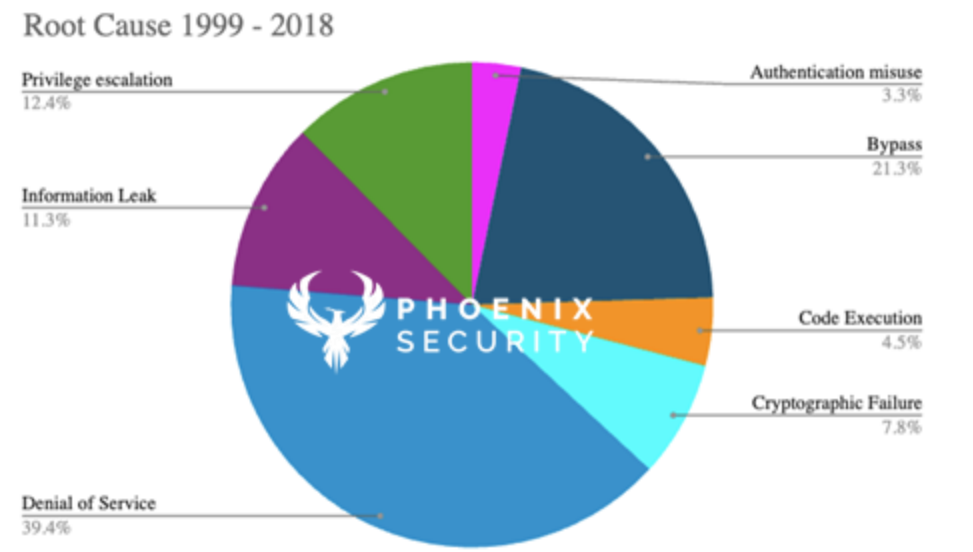


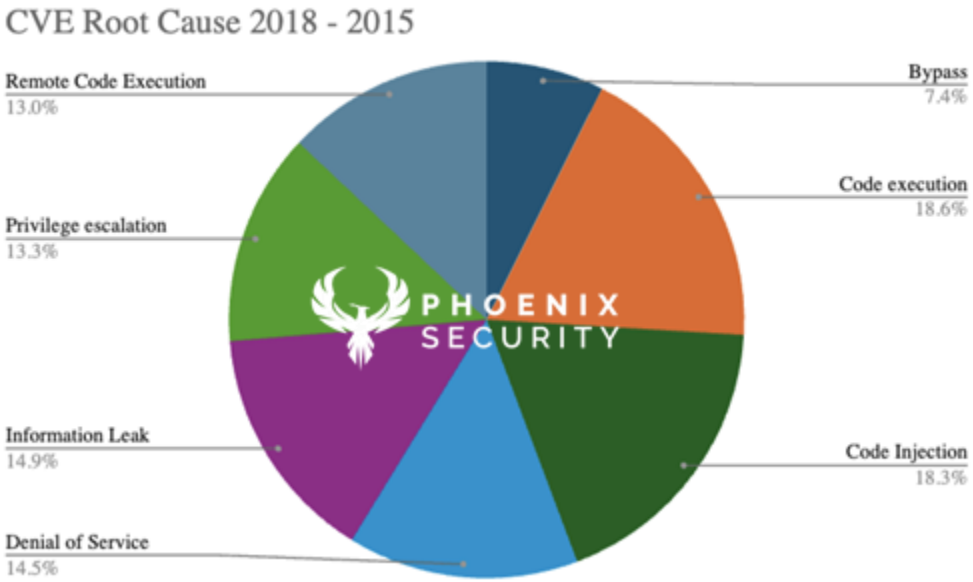
How the Path has changed … and not -> root cause and…

How the Path has changed … and not -> …and technical impact

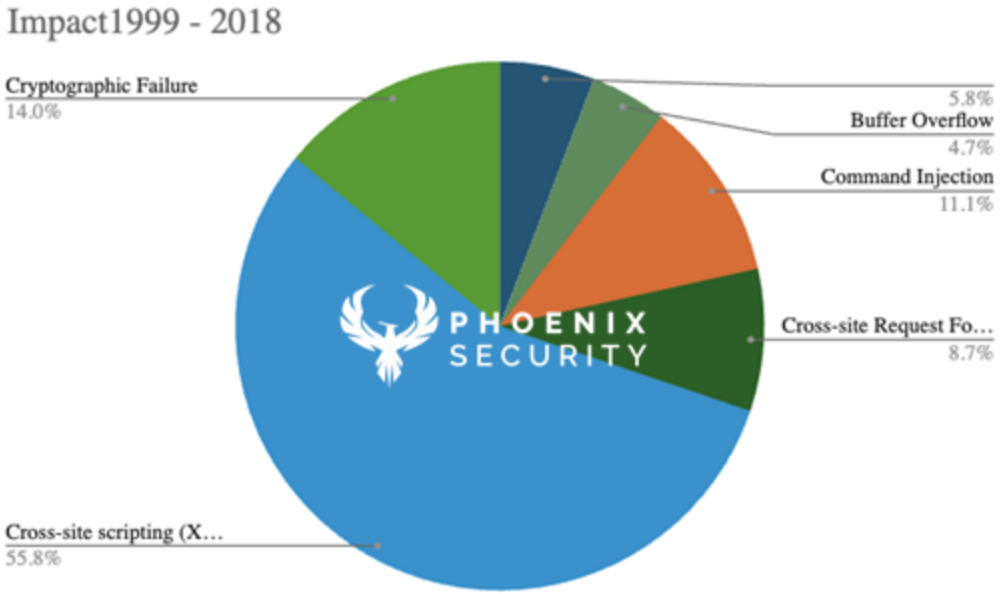
How the threat have evolved

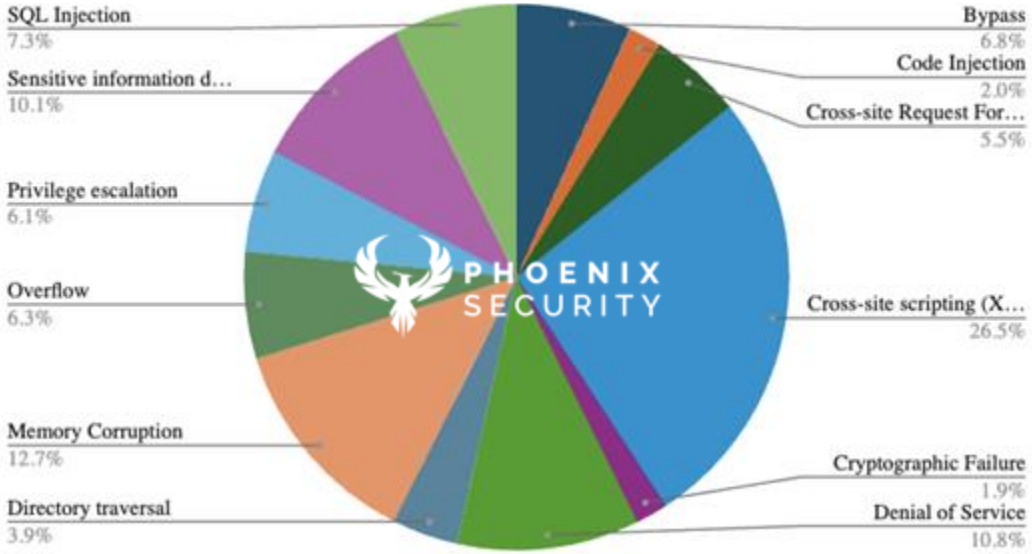
Technical Impact





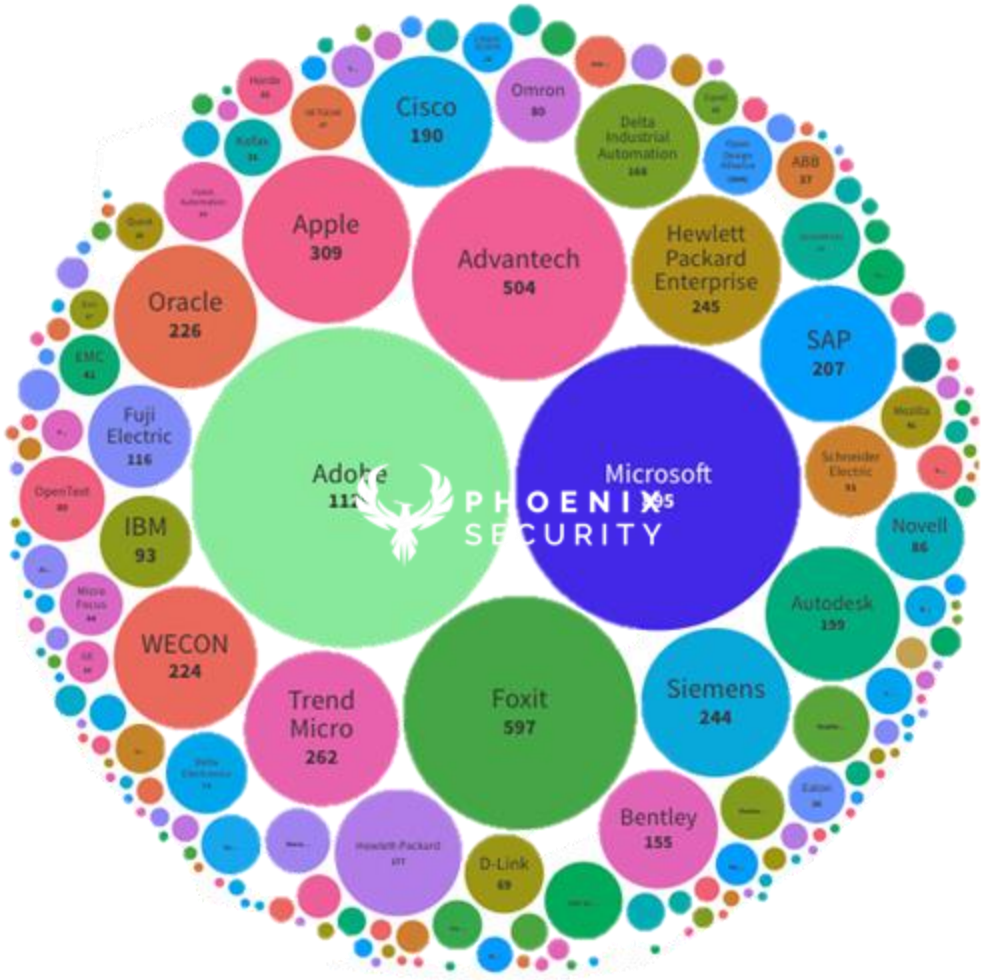
Root Cause / Weakness



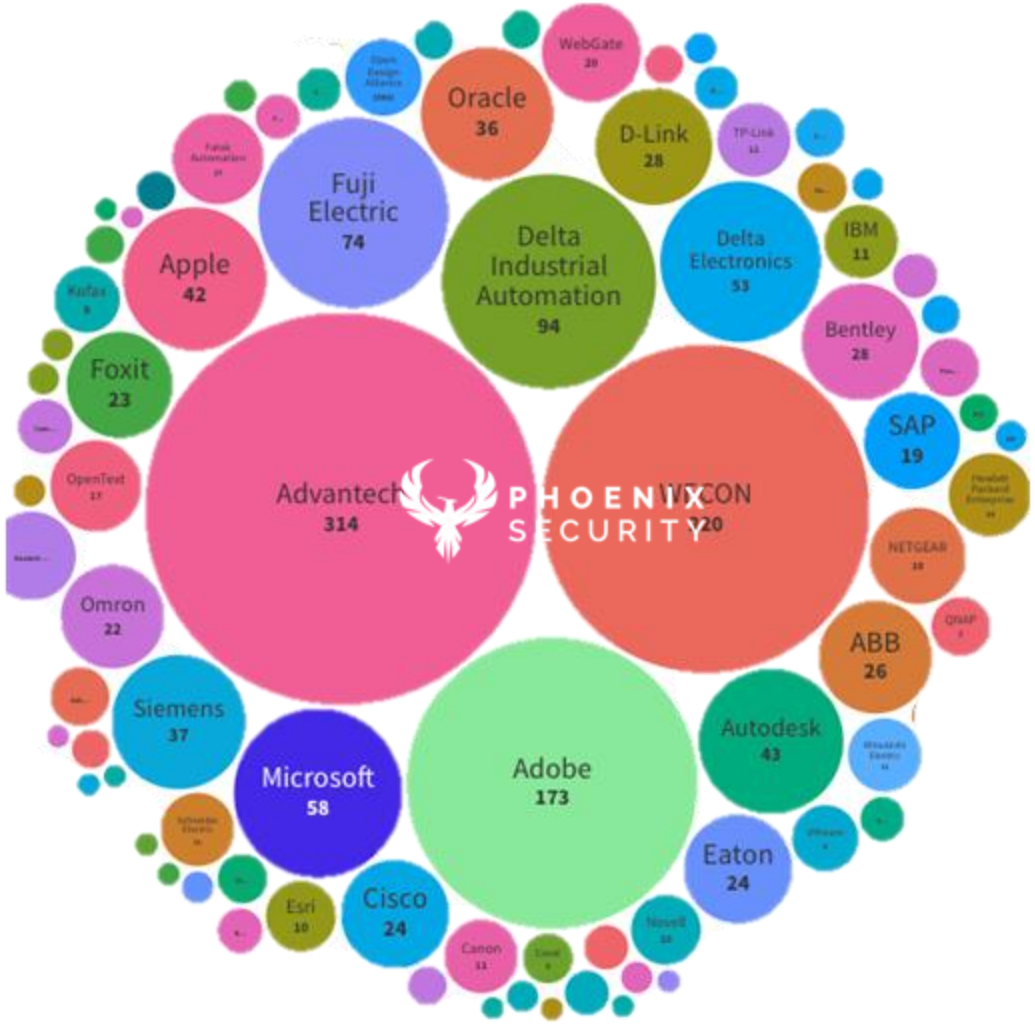


Methodologies of attacks in Zero Days

Root Cause : RCE

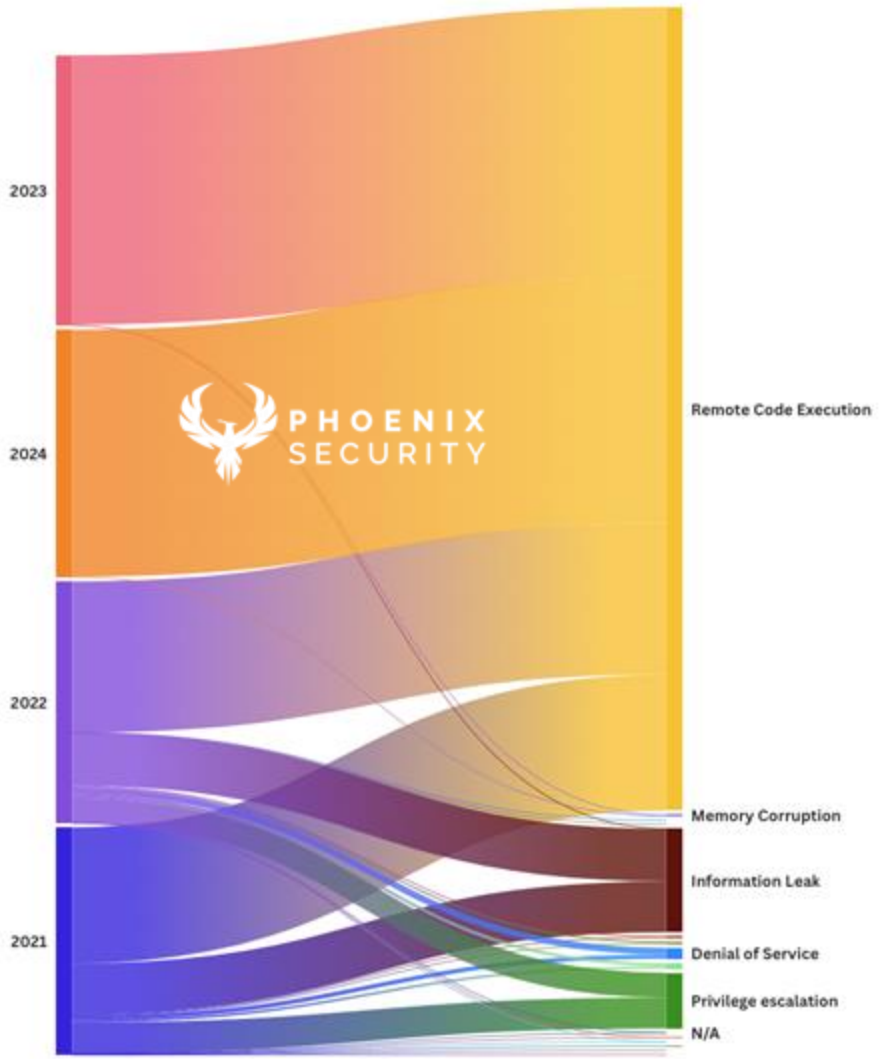


Root Cause : Buffer Overflow

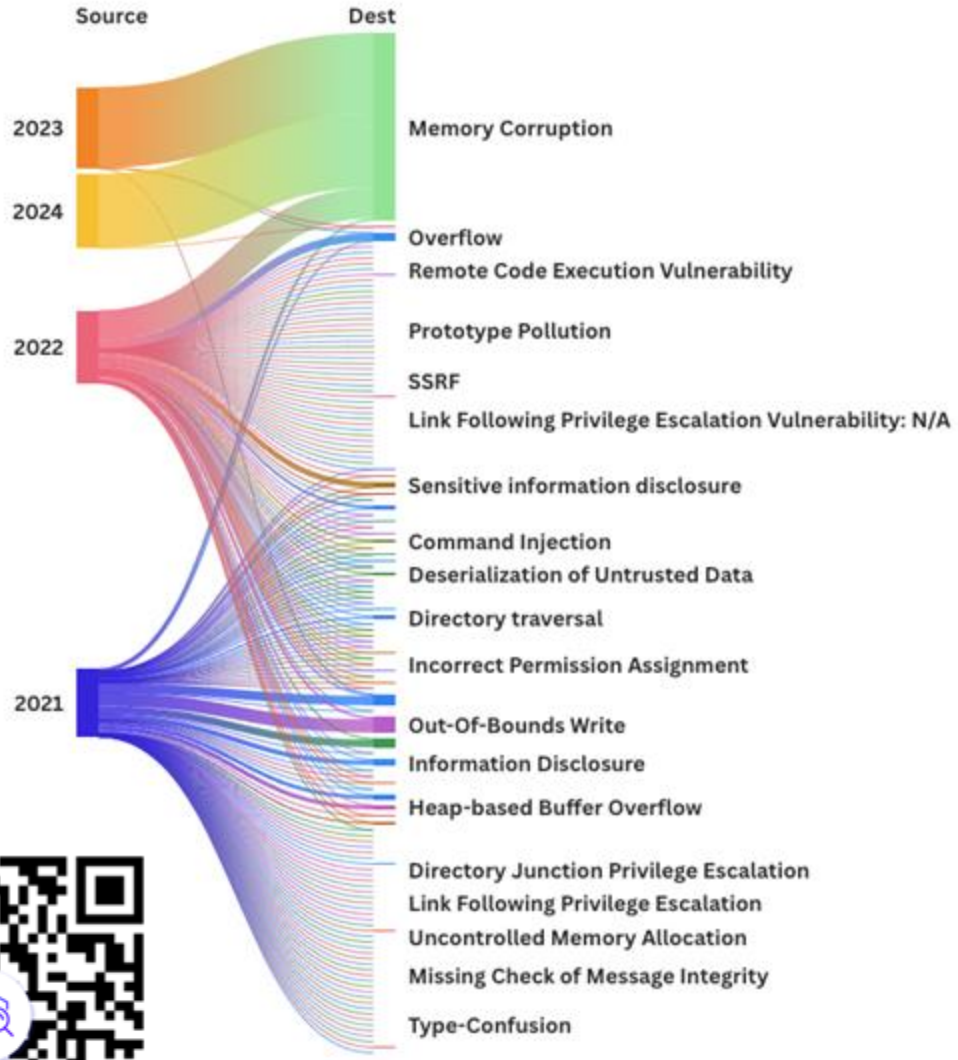


Methodologies of attacks in Zero Days - Weakness

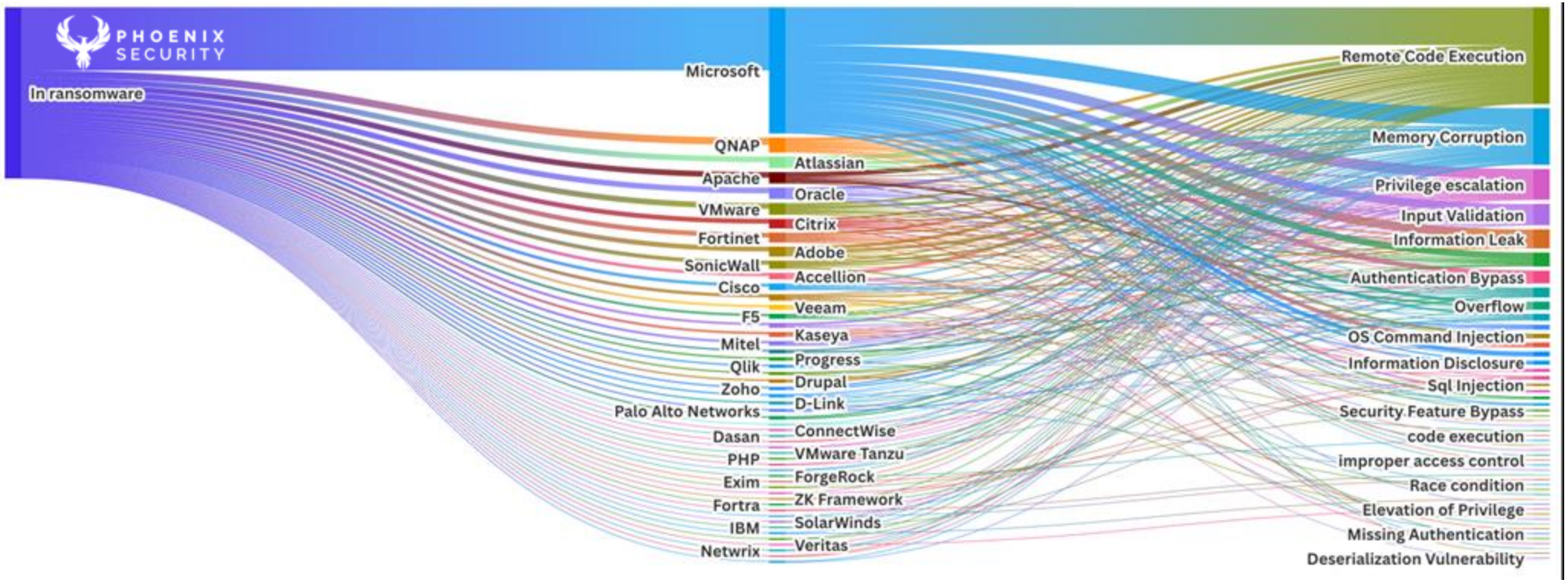
Root Cause : RCE



Technical Impact: Mem Corruption

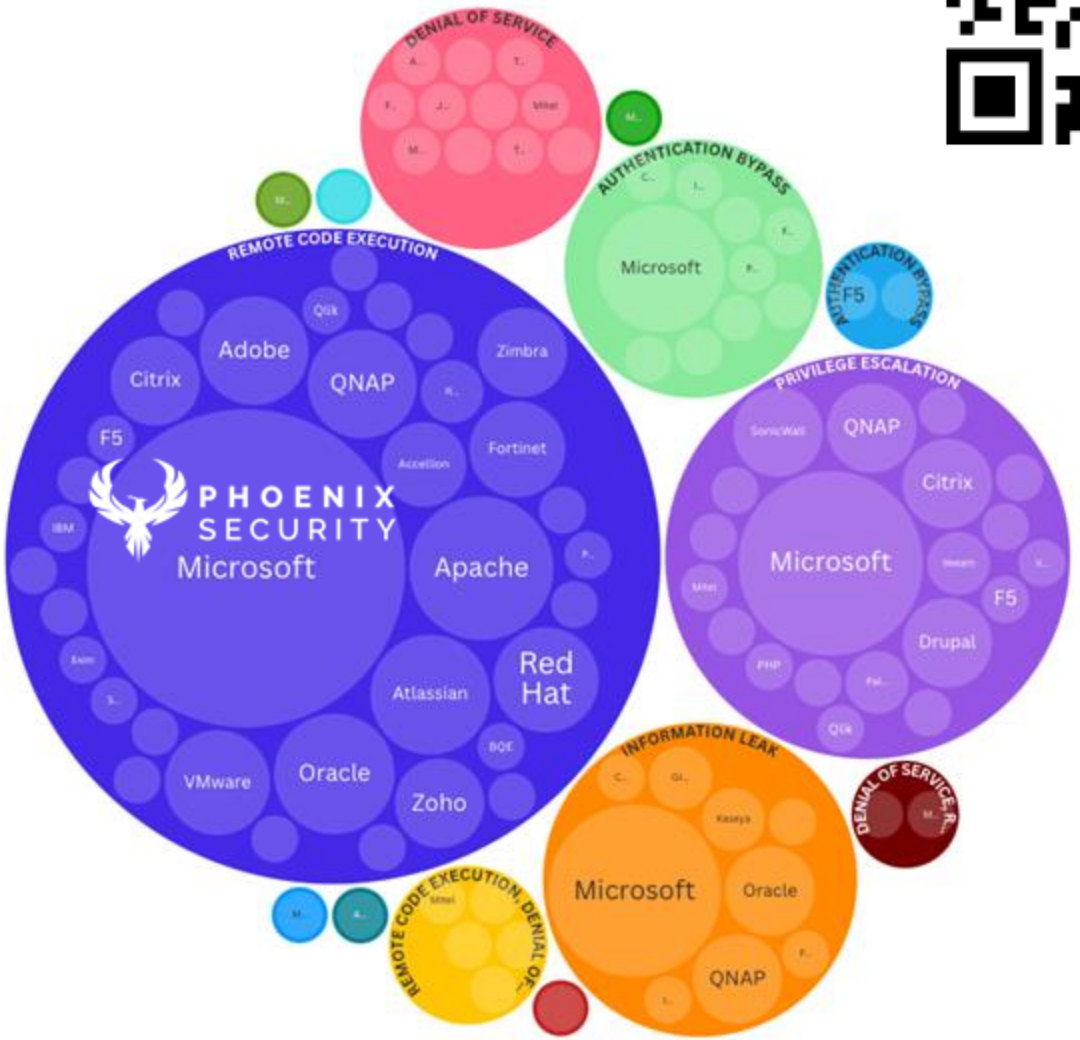


Methodologies of attacks in Ransomware

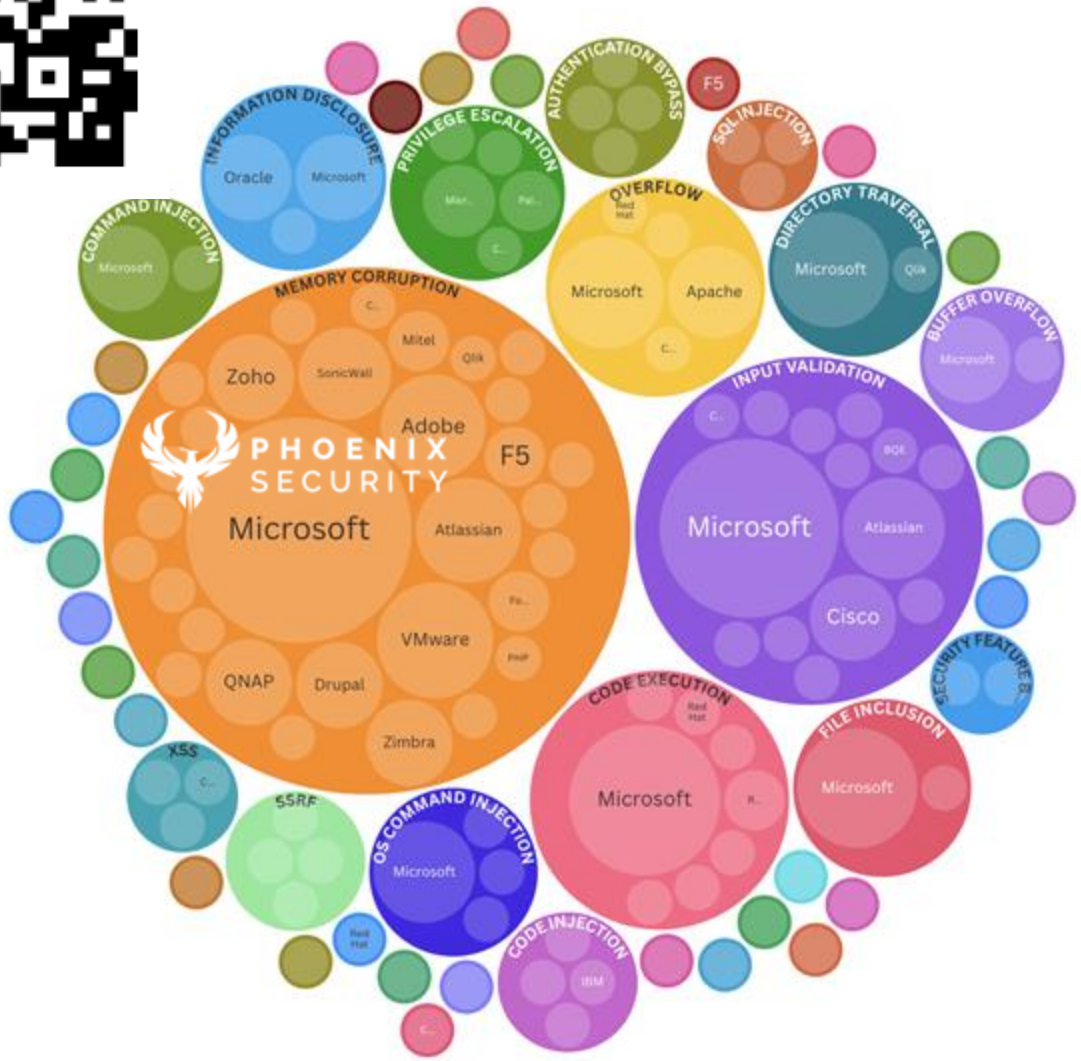


Methodologies of attacks in Ransomware

Technical Impact

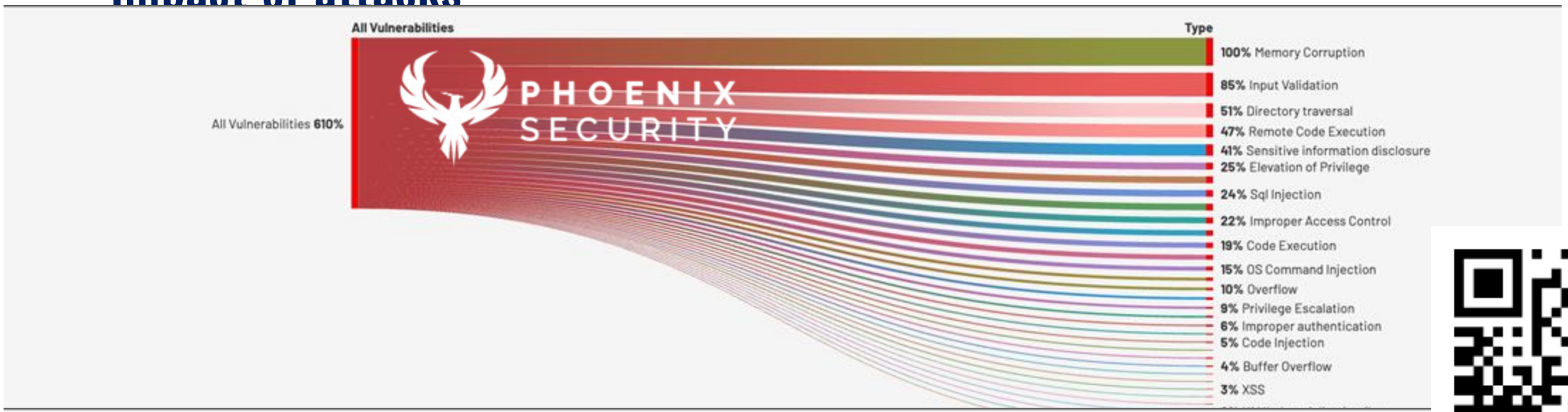


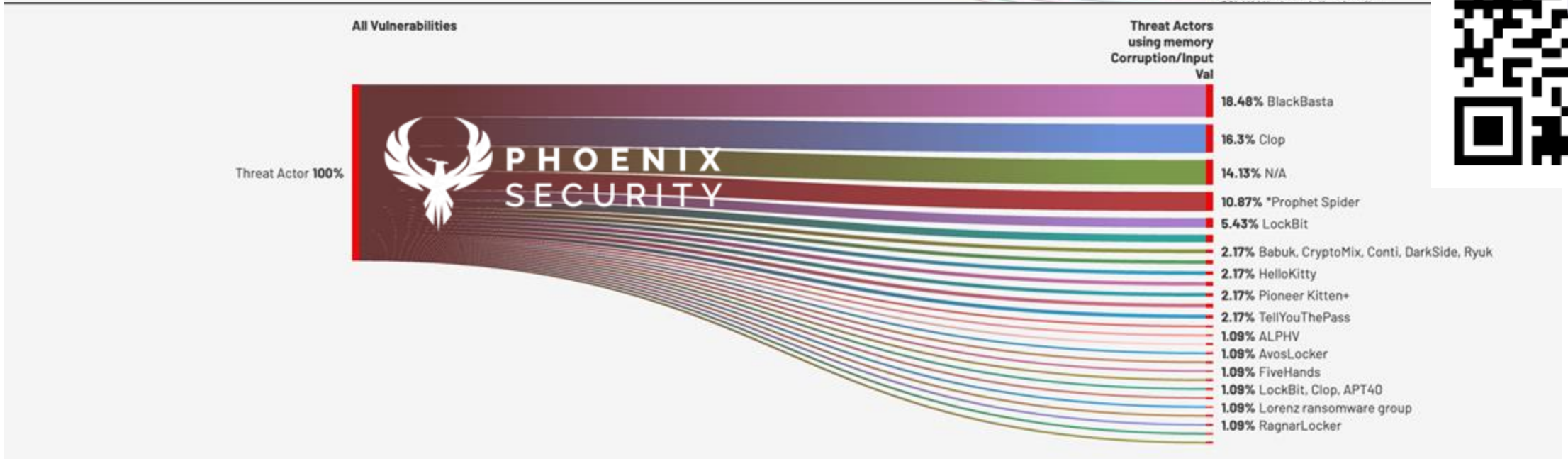
Root Cause



Methodologies of attacks

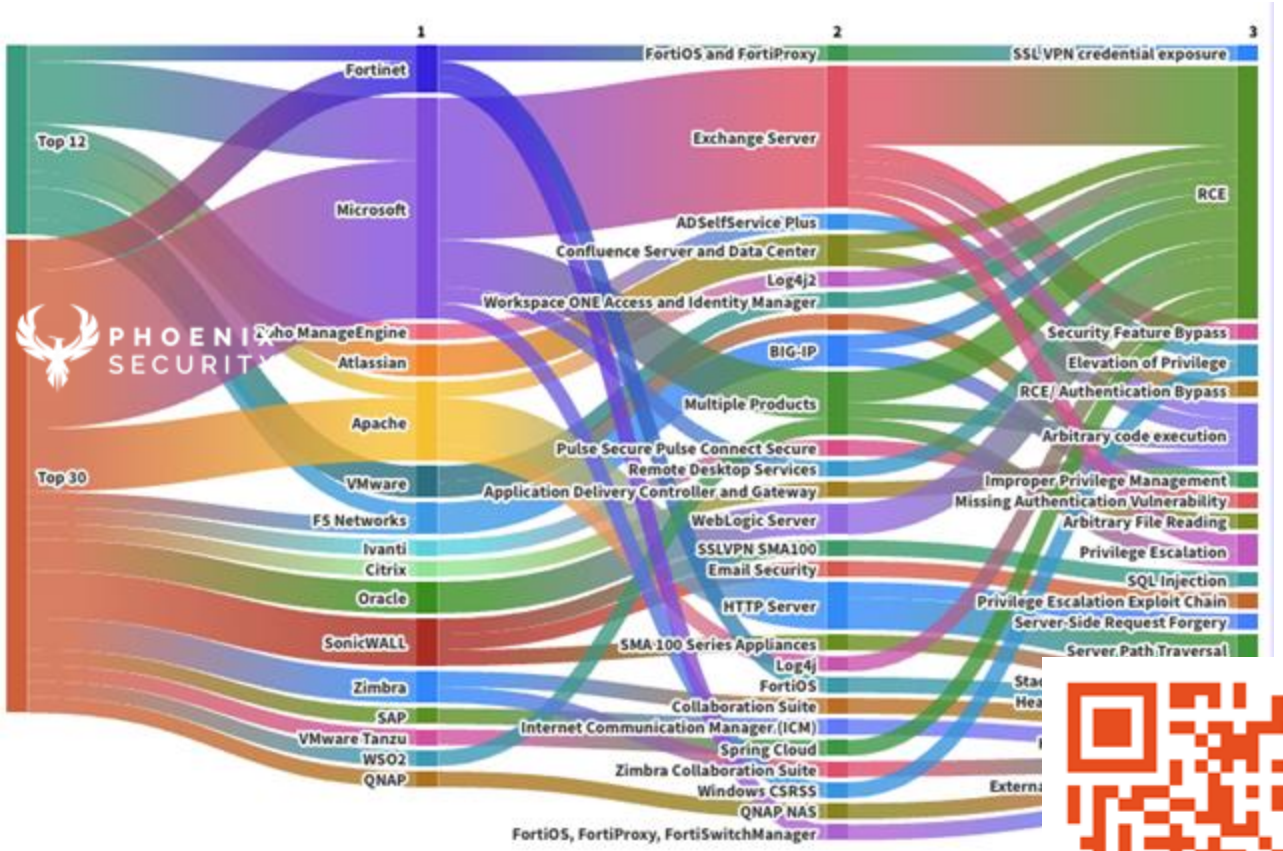
Impact of attacks



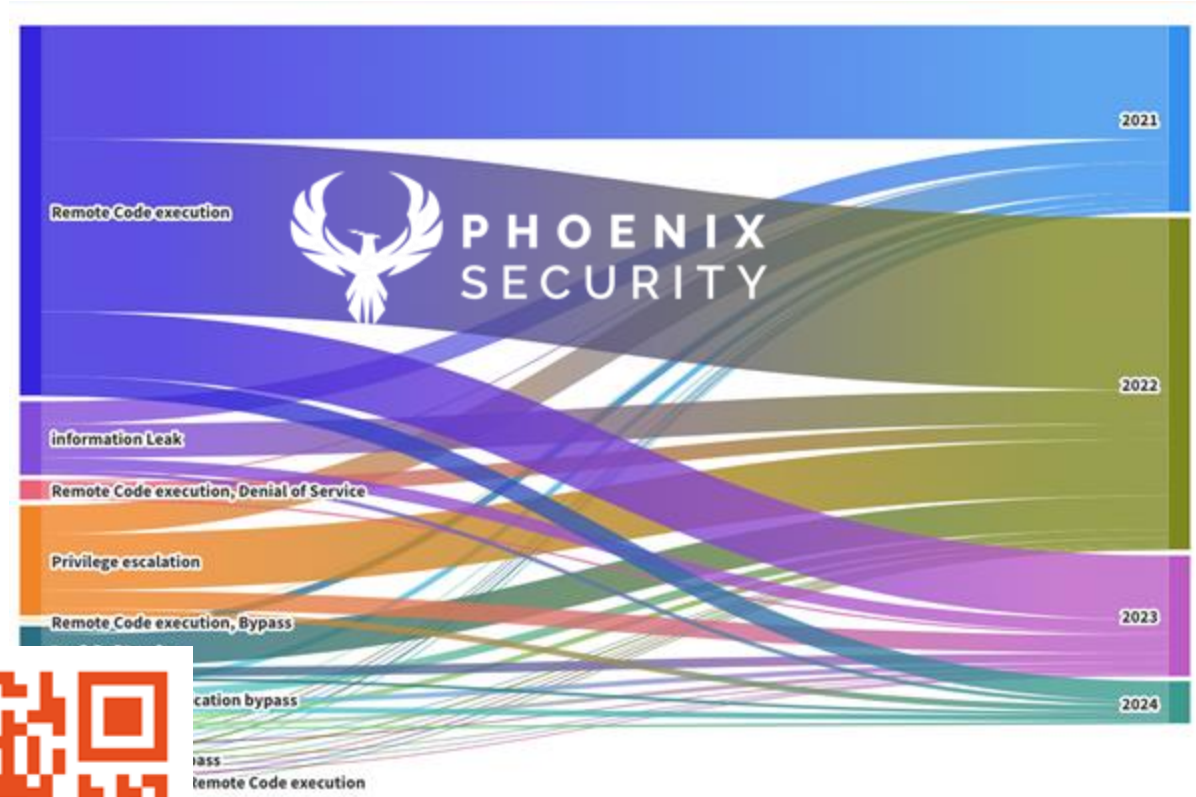


Phoenix CTI - MOST USED ATTACK METHODS

TOP EXPLOITS METHODS

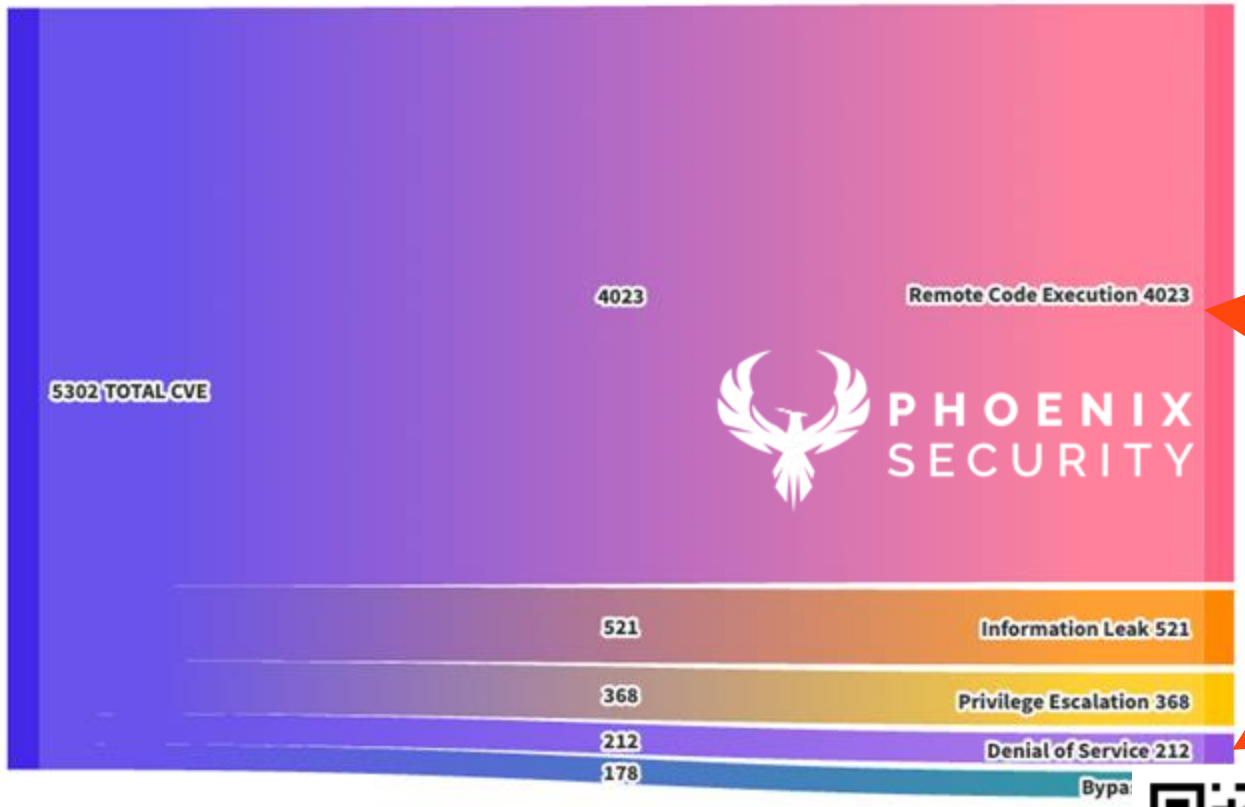


CISA KEV

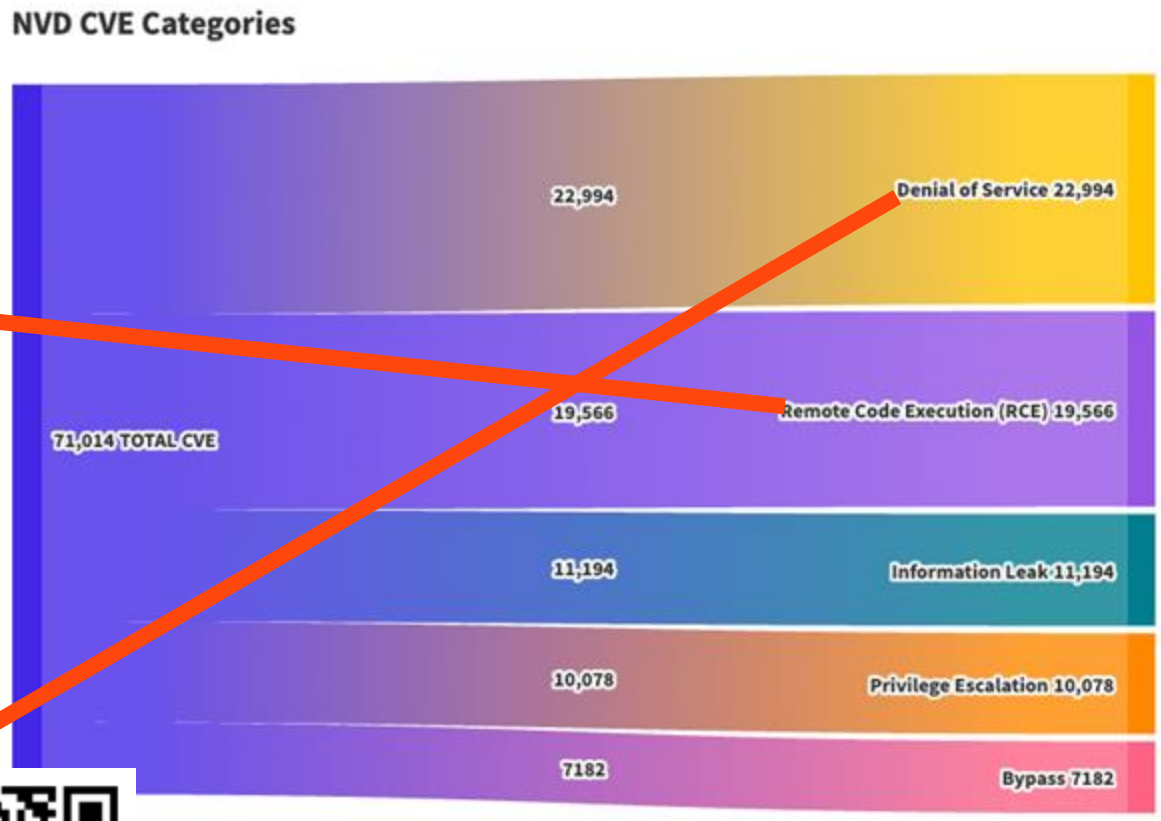


Phoenix CTI – Github PoC – Most used Method

TOP EXPLOITS METHODS

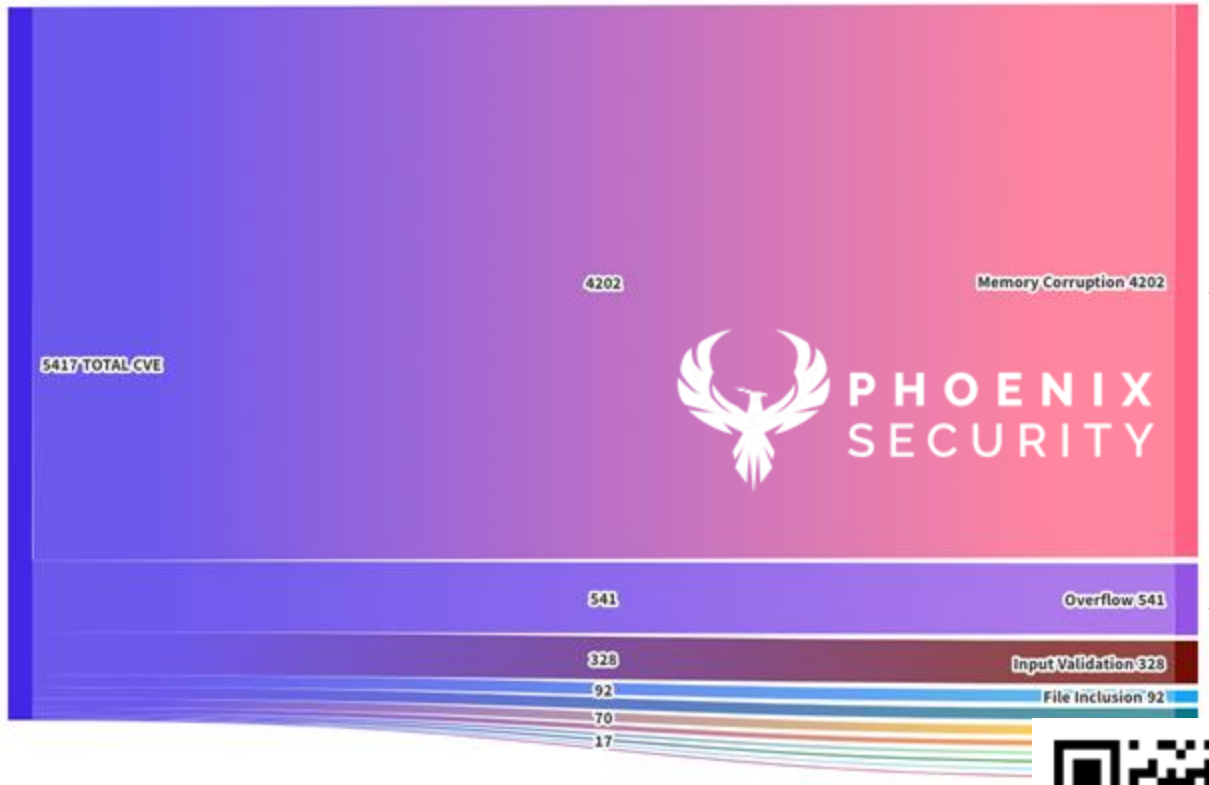


Overall NVD

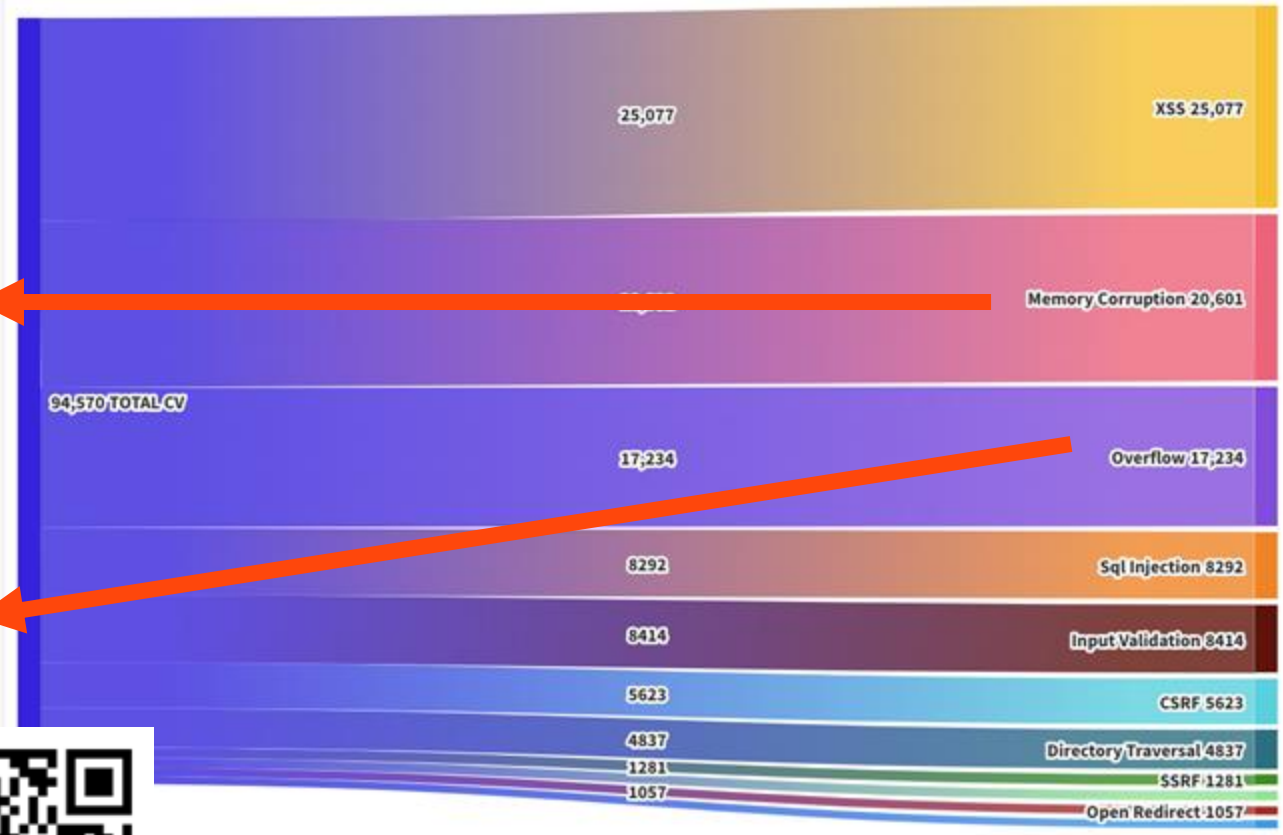


Phoenix CTI – Github PoC – prevalent technical impact

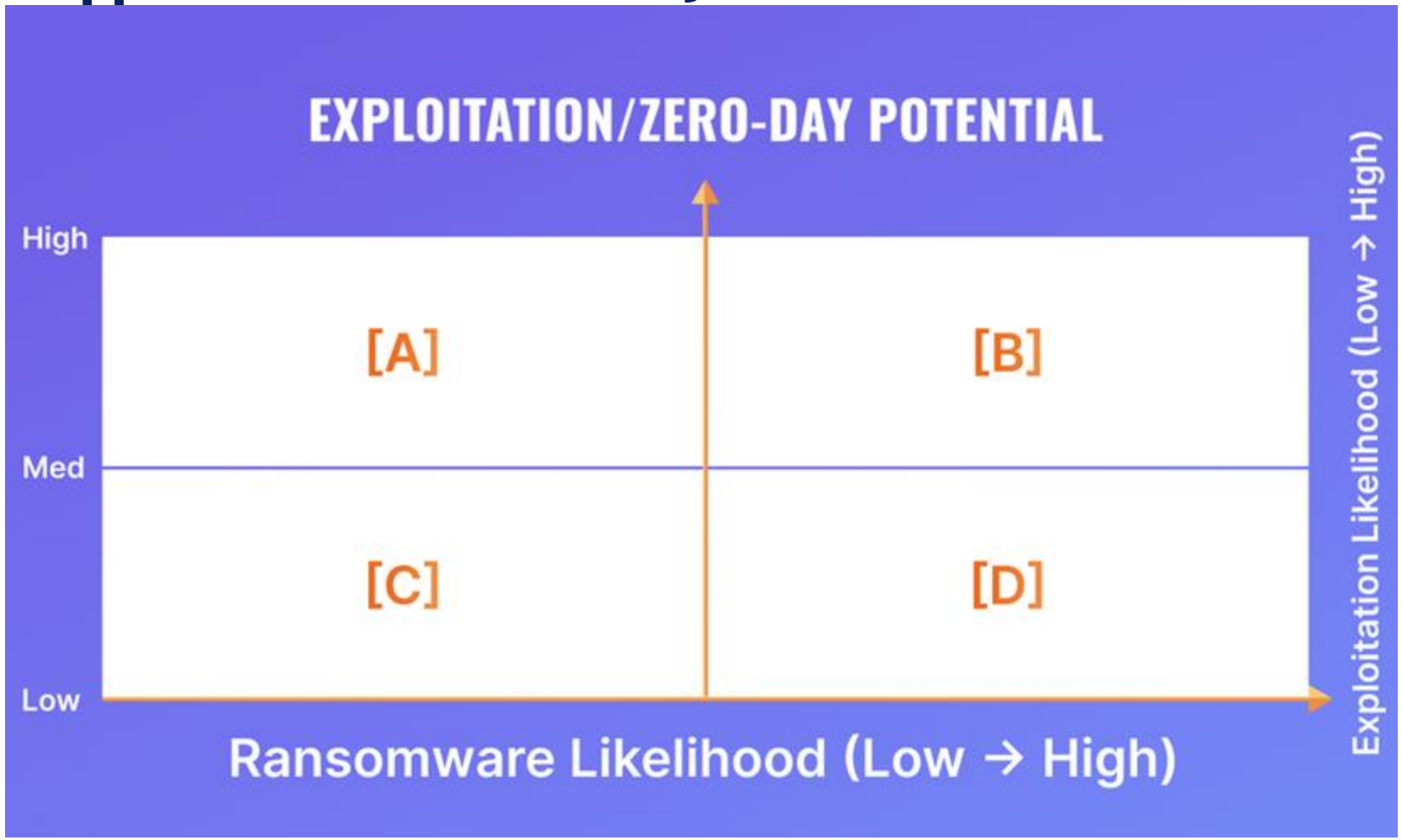
TOP EXPLOITS IMPACT



Overall NVD

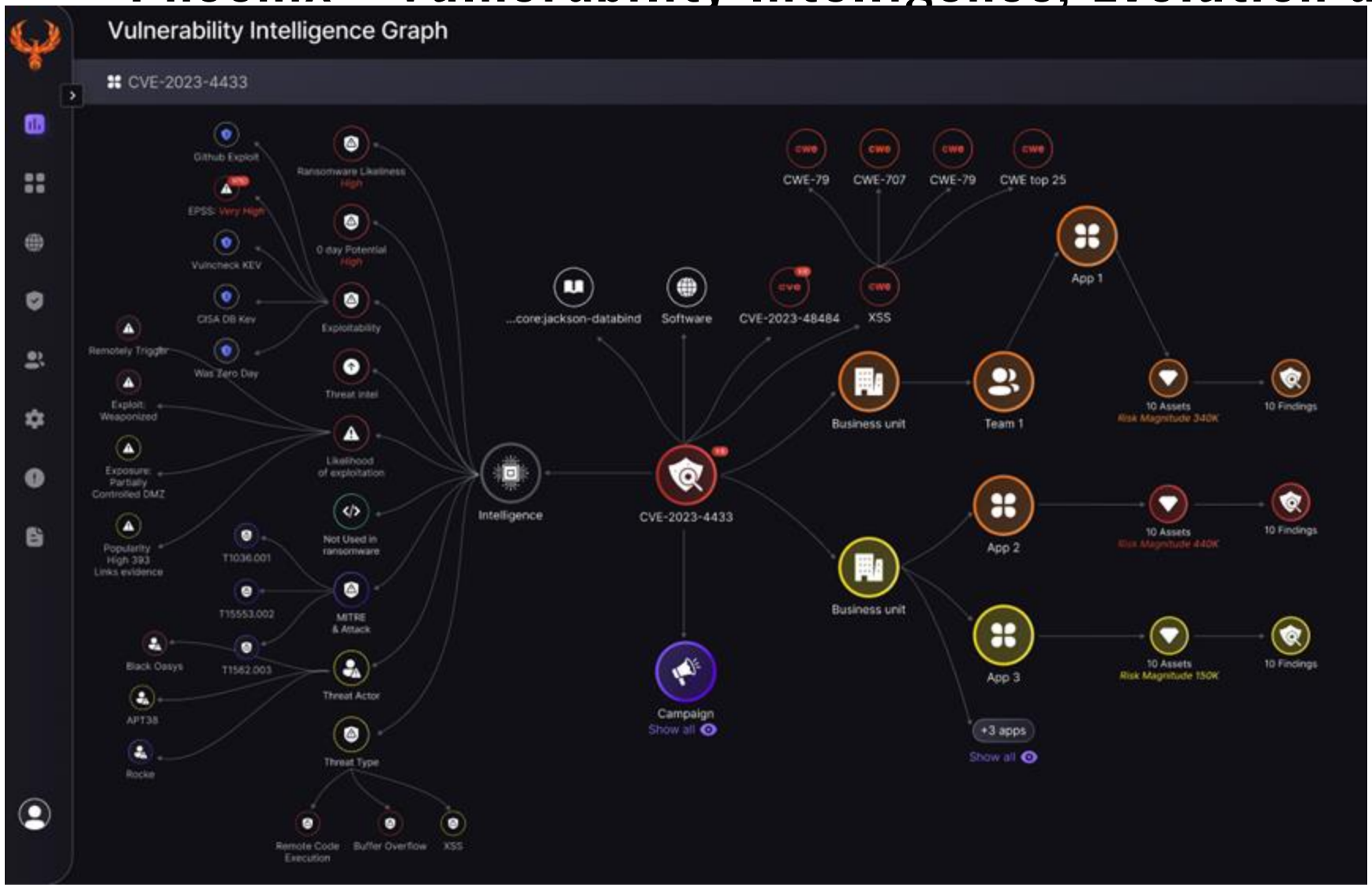


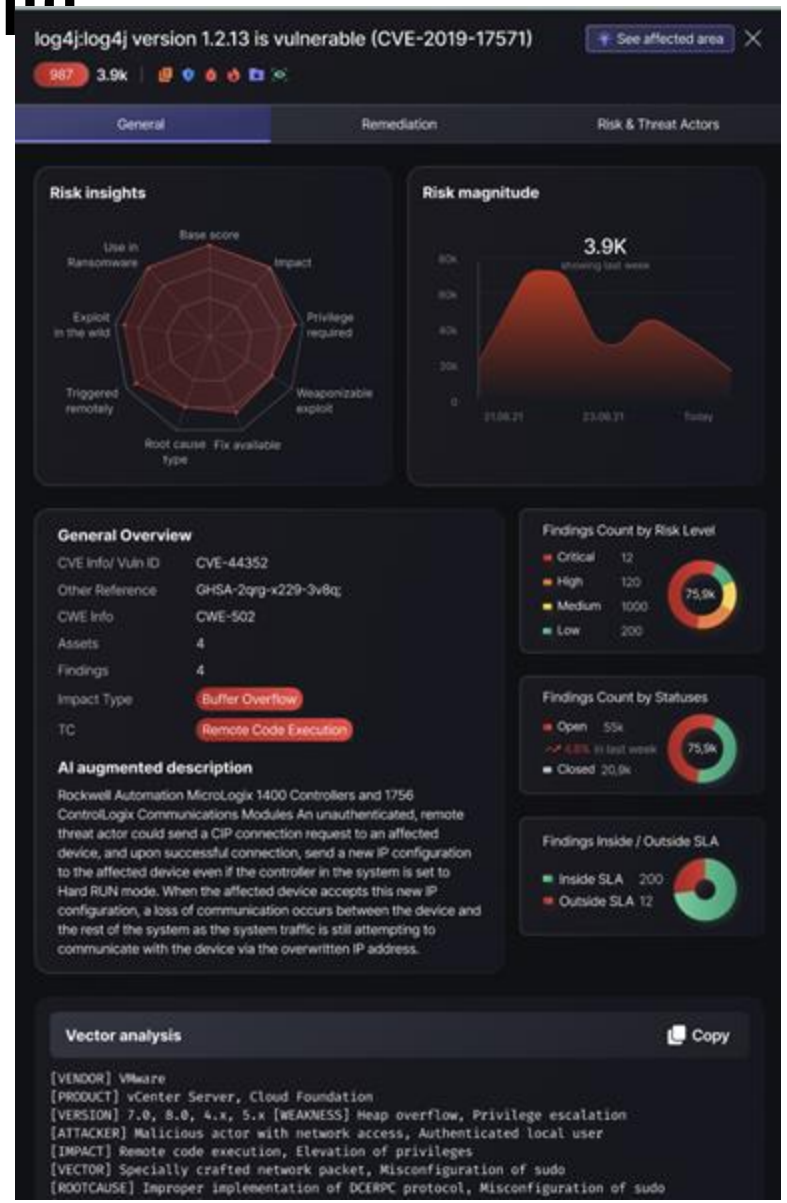
Phoenix – Introducing the world first threat centric approach on vulnerability



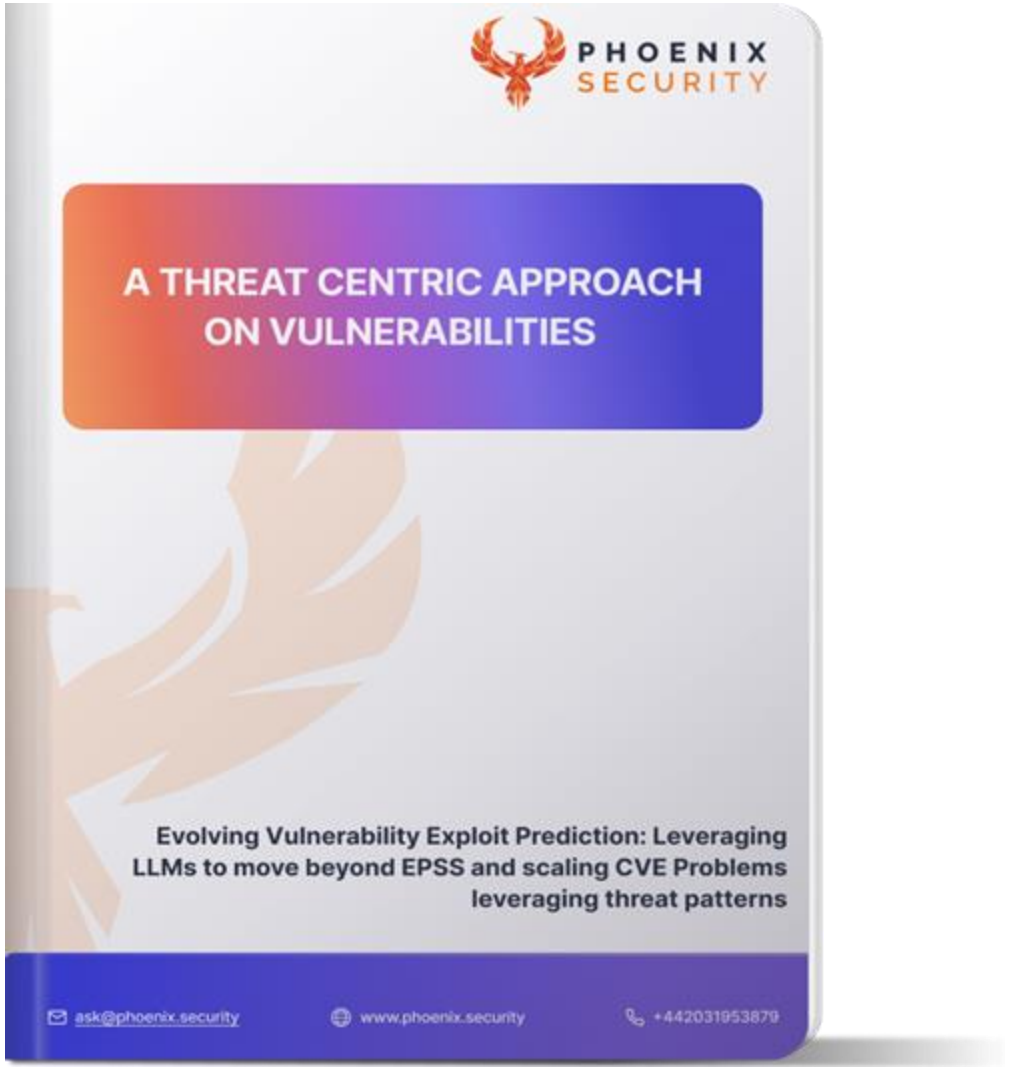
Releasing the new Threat Centric Approach on vulnerabilities

Phoenix - Vulnerability Intelligence, Evolution and



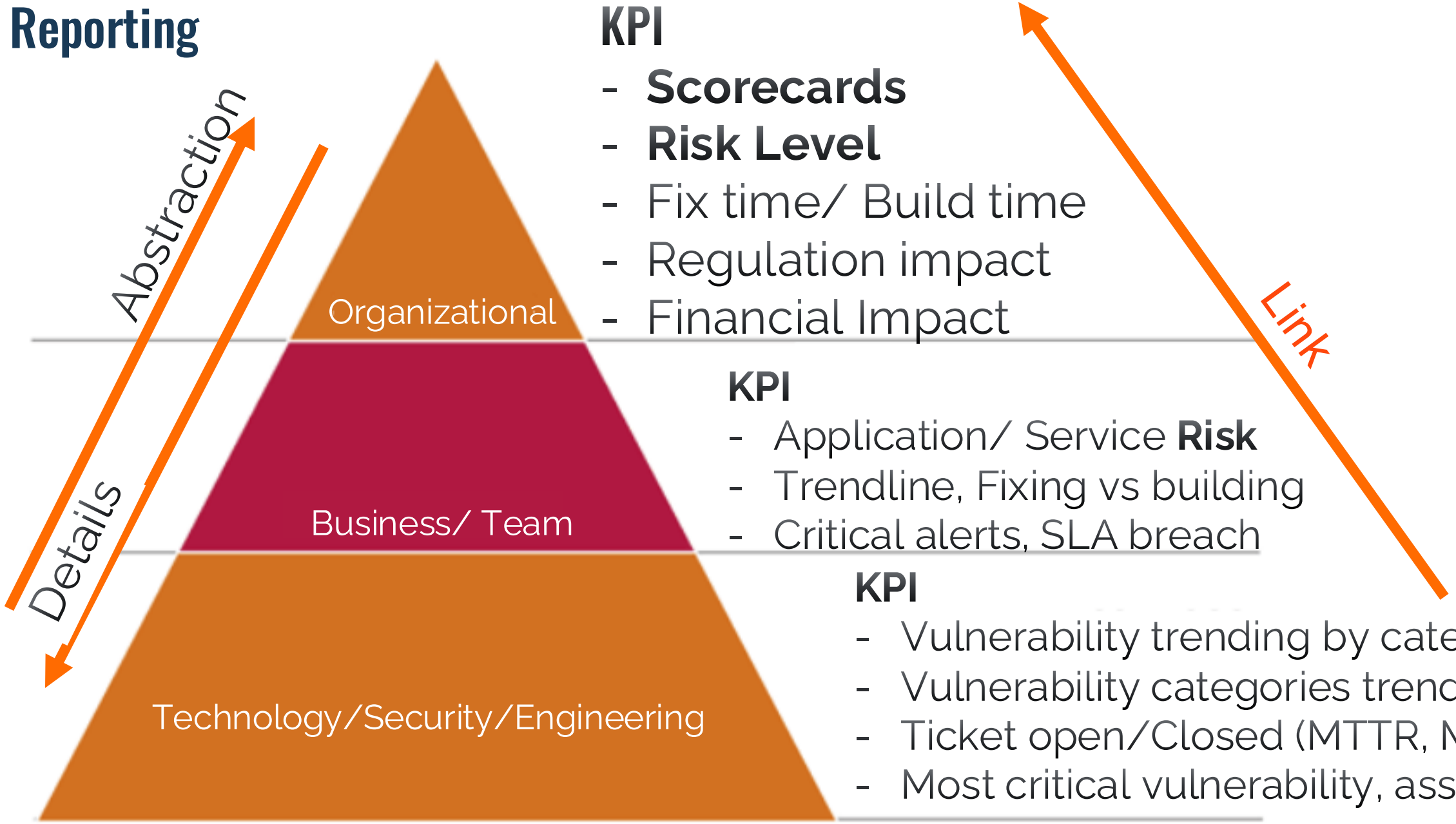


How we did it - New eBook - Threat Centric Approach



Appendix

Reporting



KPI

- **Scorecards**
- **Risk Level**
- Fix time/ Build time
- Regulation impact
- Financial Impact

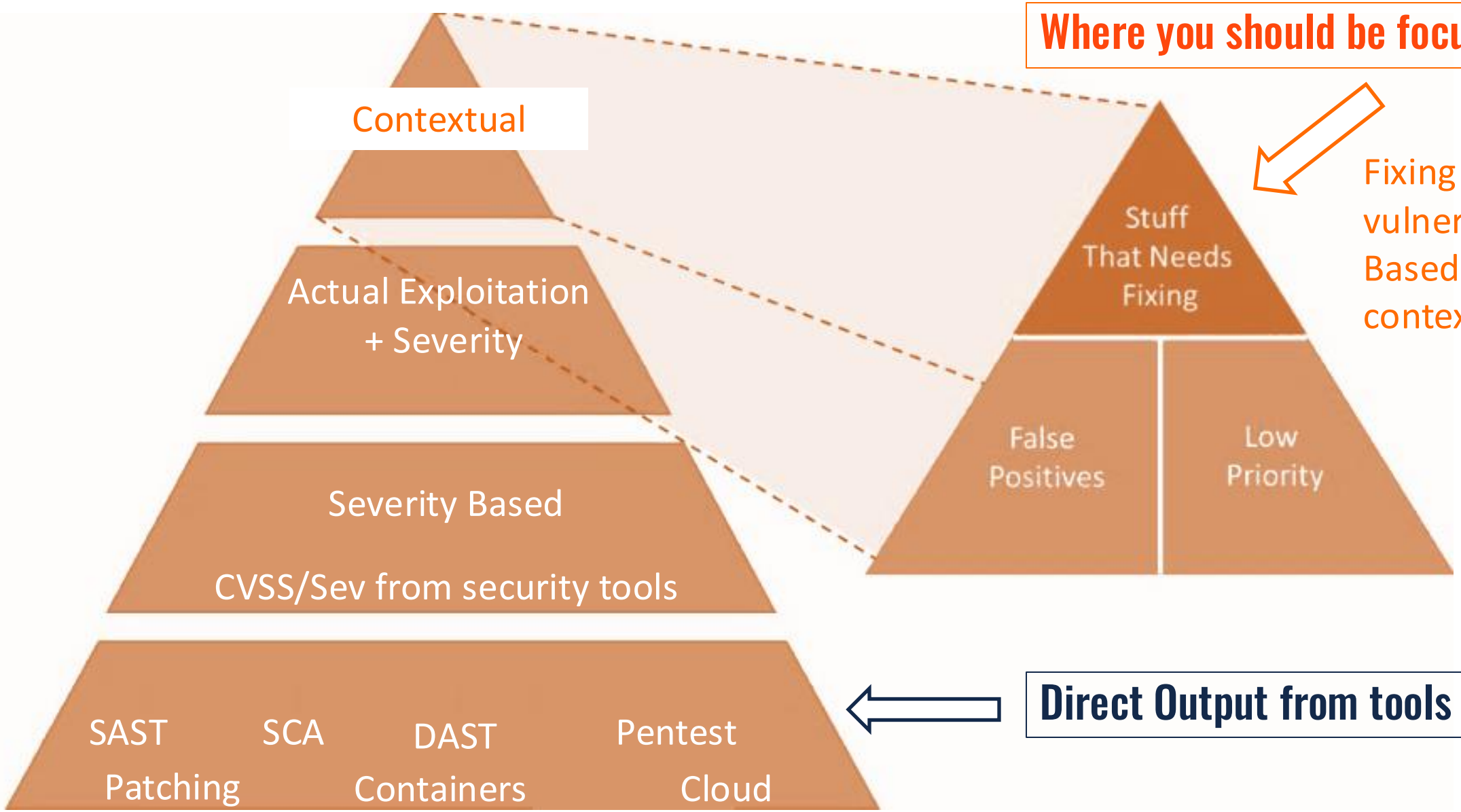
KPI

- Application/ Service **Risk**
- Trendline, Fixing vs building
- Critical alerts, SLA breach

KPI

- Vulnerability trending by categories
- Vulnerability categories trending
- Ticket open/Closed (MTTR, MTTO)
- Most critical vulnerability, assets

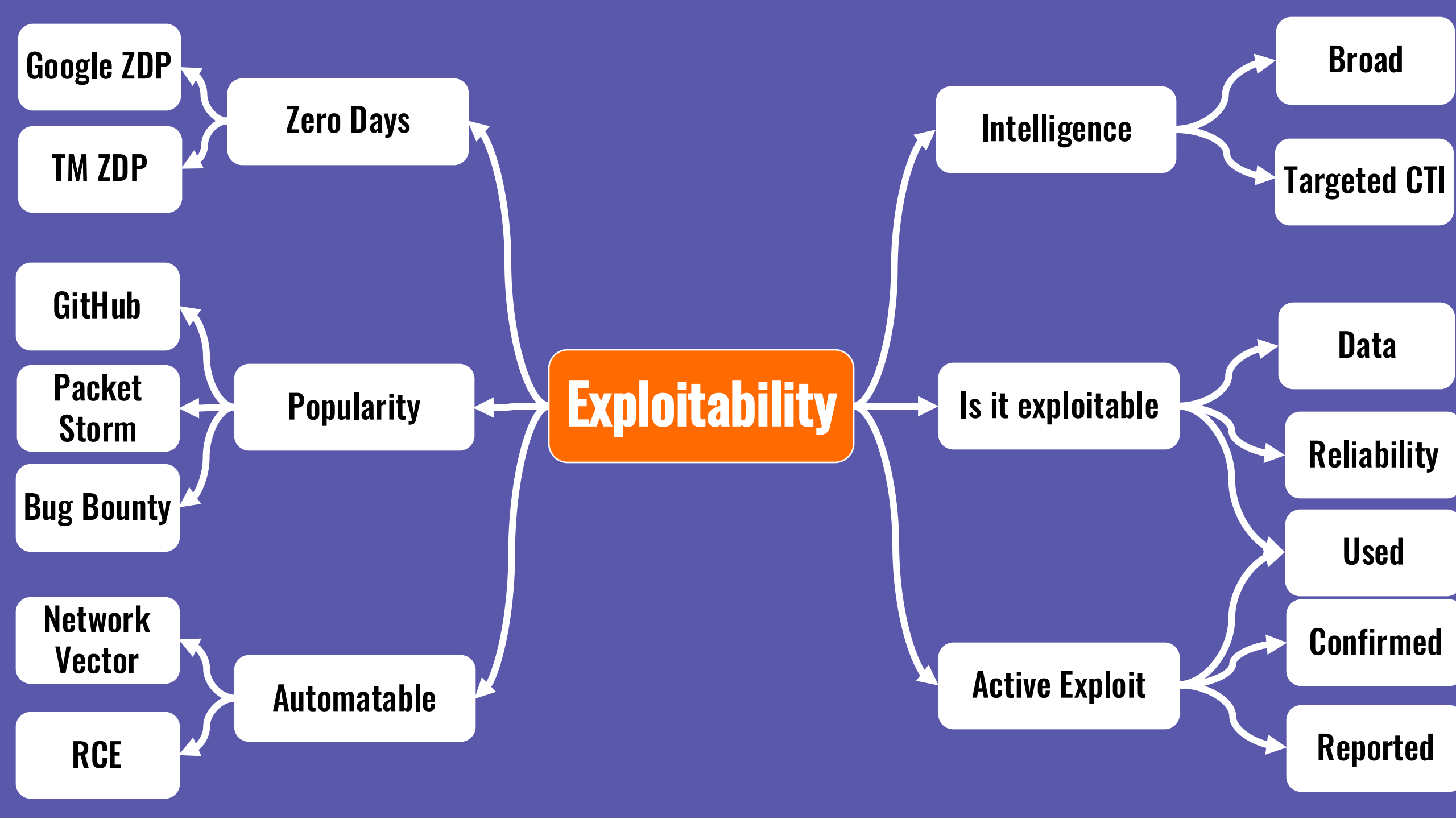
Prioritization is so 90....

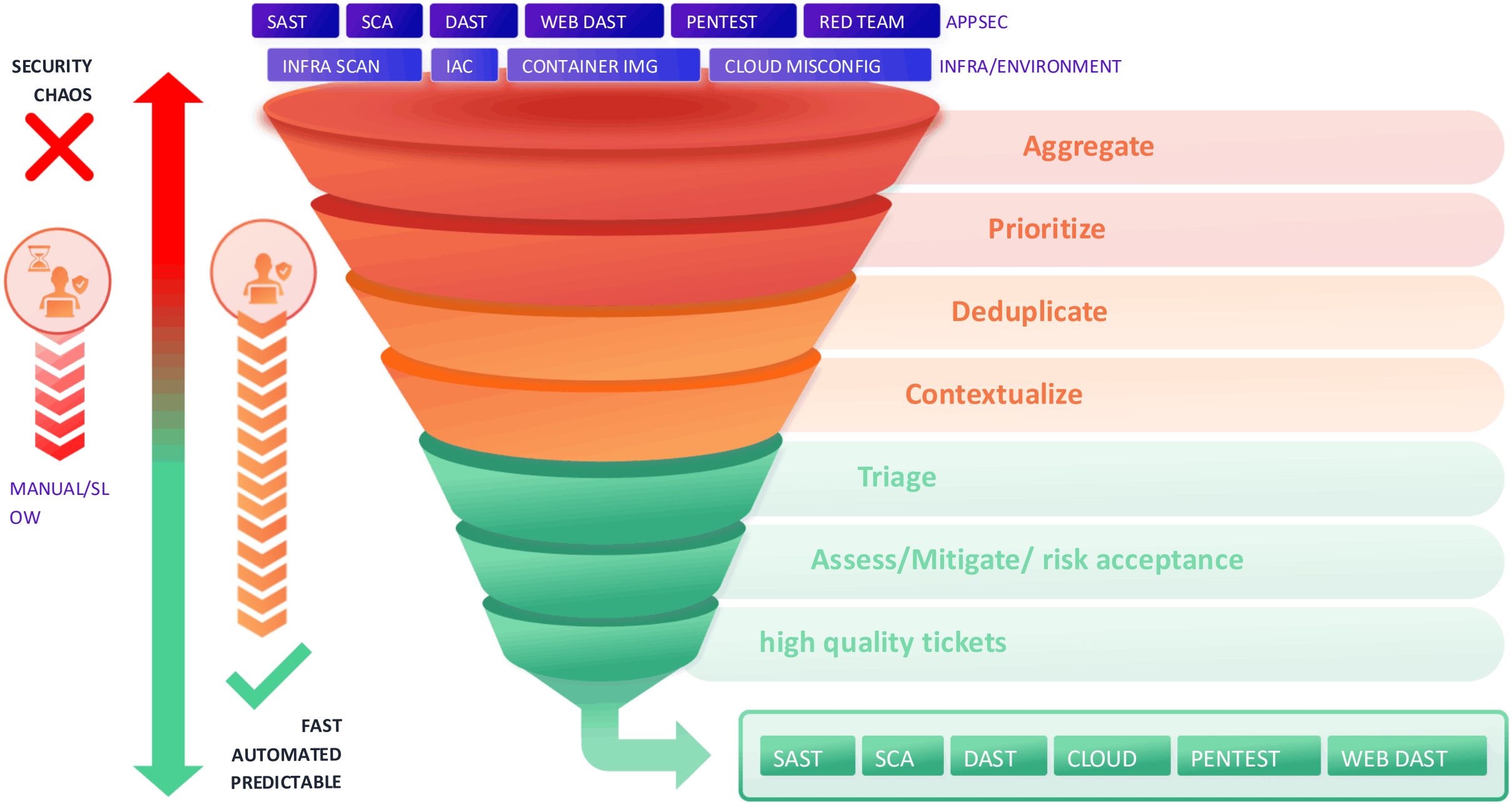


Where you should be focusing

Fixing vulnerabilities Based on contextual risk

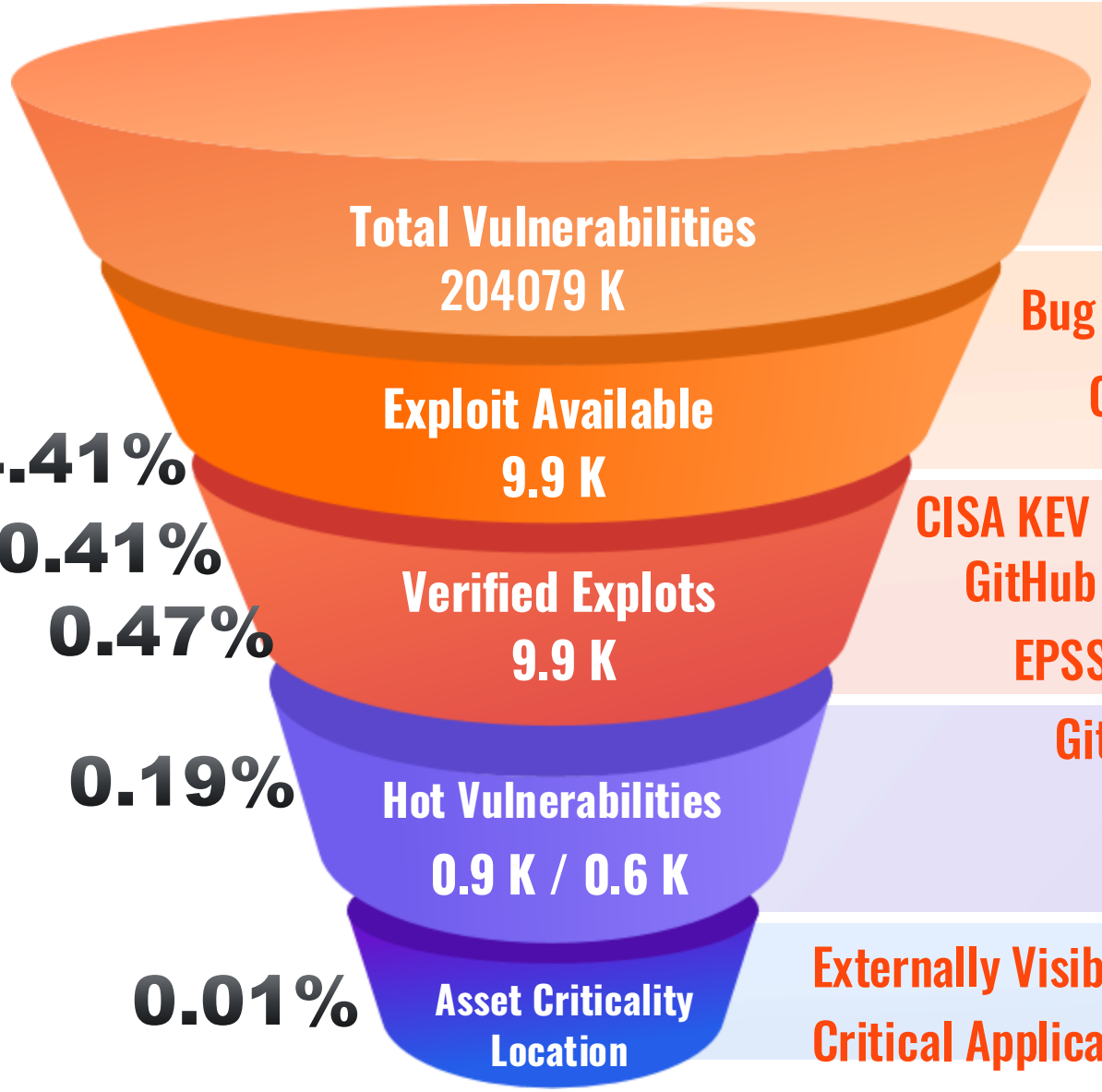
Direct Output from tools


Exploitability
Zero Days
Google ZDP
TM ZDP
Popularity
GitHub
Packet Storm
Bug Bounty
Automatable
Network Vector
RCE
Intelligence
Broad
Targeted CTI
Is it exploitable
Data
Reliability
Active Exploit
Used
Confirmed
Reported



CONTEXTUALIZE PRIORITIZE | ACT ON RISK THAT MATTERS MOST

Not all the vulnerabilities require equal attention



4.41%

0.41%

0.47%

0.19%

0.01%

Bug Bounty Popularity (active 17K) 8.33%

GitHub Exploit (9.9K) 4.41%

CISA KEV (1K) 0.41%

GitHub Verified Exploits (0.93K) 0.47%

EPSS > 0.7 (688) 0.33%

GitHub Active Exploit (0.40K) 0.19%

RCE 0.43%

Externally Visible (0.14) ?

Critical Application 0.?%